

Privacy and Data Protection Online: The Laws Don't Work?

LILIAN EDWARDS¹

PRIVACY IS NOT a simple subject, especially online privacy. What kind of value is privacy? How far should the law protect it? What balance should be struck between the individual's right to privacy and the duty of the society to protect its people from terrorism and crime? Is privacy an objective concept, important in the same way to all persons, or is it an inherently subjective value, in which case how should or can a balance be struck against other values, not restricted to security, but including freedom of expression and the promotion of the market? Is privacy solely an individual right, or does society as a whole have a stake in the preservation of privacy as a common good?

If we decide (as historically, we have) that privacy is a value worthy of protection by *law*, how should this be done, and who should enforce such rules, both against the state, and against commercial and private interests? And, of particular significance in this chapter, can rules protecting 'data privacy' be practically enforced in the transnational, borderless, information-dense world the Internet has now created?

Questions like these have long been contested both in law and in society,

¹ My grateful thanks to Rowena Rodrigues, PhD student, University of Edinburgh for substantial research assistance; to Judith Rauhofer, Lecturer, UCLAN, for many helpful insights and arguments as to the nature of privacy as a value and a right; to Ian Brown, Research Fellow, Oxford Internet Institute; and Chris Marsden, Senior Lecturer, Essex University, for collaboration on research on the social networking site parts of this chapter, and general advice; and to Hector MacQueen for comments on the draft. Any errors are of course the author's alone.

Parts of this chapter appeared in earlier and considerably different forms in L Edwards and L Rodrigues, 'The Right to Privacy and Confidentiality for Children: The Law and Current Challenges', in C Clark and J McGhee (eds), *Private and Confidential?: Handling Personal Information in Social and Health Services* (London, Polity Press, 2008); L Edwards, 'Reconstructing Consumer Privacy Protection On-line: A Modest Proposal' (2004) *International Journal of Law, Computers and Technology* 314; and in L Edwards and I Brown, 'Data Control and Social Networking: Irreconcilable Ideas?', in A Matwyshyn (ed.) *Harboring Data: Information Security, Law and the Corporation* (Stanford, Stanford University Press, 2009, forthcoming). Available in draft version at SSRN: <http://ssrn.com/abstract=1148732>.

² See Edwards, ch 15.

and will recur throughout this and the following four chapters. They will not be solved in this brief introduction. Instead, this chapter attempts to give a very basic legal grounding on privacy and data protection law, which will be built upon in specific key instances such as spamming² and other forms of online marketing and data collection,³ state surveillance⁴ and data retention⁵ in subsequent chapters.

First, we will briefly consider what the legal rules are which seek to protect the privacy and confidence rights of individuals in the UK and Europe and how they evolved; secondly, we will focus on how effectively (or not) these rules operate in the context of the Internet and the information society; thirdly, we will consider some key recent societal developments which suggest that privacy is declining in significance as a societal value, while 'openness' is in the ascendant; finally some brief conclusions will be reached on the purported 'death' of informational privacy, the future of data protection (DP) law and how technology as well as law can help protect personal data.

I. PRIVACY PROTECTION AND THE LAW

The two most important legal regimes to consider in privacy protection in the UK are DP law, and the law of confidence. DP law in the UK is to be found in the Data Protection Act 1998 (DPA), itself derived from the European Data Protection Directive (DPD) (see below p 452), which harmonises this legal area across the EU. The law of confidence, on the other hand, is a creature of the common law, and is idiosyncratic to English law (Scots law, however, sharing most of the same rules). Both regimes, have been informed, and, in the case of the law of confidence, almost transformed in recent years, by the guarantees of a human right to private life, derived from the European Convention of Human Rights (ECHR), Article 8; especially since the incorporation of this instrument into UK domestic law in the Human Rights Act 1998. Since the 1998 Act, the right to private life as a fundamental human right can now be plead in any court in the land, with no need to go to the European Court of Human Rights (ECtHR) in Strasbourg to raise the issue.⁶ Public bodies (such as social work depart-

³ See Edwards and Hatcher, ch 16.

⁴ See Rauhofer, ch 17.

⁵ See Rauhofer, ch 18.

⁶ It is beyond the scope of this chapter to examine fully ECtHR case-law in this area but it is worth noting that there has been a clear growth in cases emanating from Strasbourg which have significant effects on the law of data protection: notably just in the last 12 months, *I v Finland*, Case 20511/03, 17 July 2008 (on how to strike a balance between journalistic freedom of expression and individual privacy); *K v Finland*, Application no 25702/94, 2 December 2008 (on the balance to be struck between disclosure of the identity of anonymous alleged offenders and privacy of said); *Reklos and Devourlis v Greece*, Application No 1234/05, 15 January 2009 (rights of parents not to have photographs of infant taken in hospital without consent); and *S and*

ments, courts and local authorities) must act in accordance with it, and (in theory at least) the government must certify that legislation passed is compliant with the ECHR. Breaches of, or failure to implement, the ECHR in state laws can still, however, be finally adjudicated by the ECtHR as a remedy of last resort.

DP protects what is known very generally as *informational privacy*: loosely, the right to control what is known about you. The type of information protected is differently defined in different countries and is not always clear (see further below) but typically includes 'personal data' such as name, address, date of birth, contact details, financial, medical and social work details, identifiable photos, relationship status, political allegiance, sexual, genetic, biometric, racial and ethnic details, school records, domestic situation, and so forth.

The law of confidence, by contrast, prevents a second party from disclosing information which should be kept private between that person and the data subject. Historically the law of confidence arose only in special well-known relationships of trust, or in a commercial 'trade secrets' context.⁷ In the seminal case of *Douglas v Hello!*,⁸ the law of confidence was significantly widened by the courts to create a near commercial right of personality. In that case, it was held that if (i) someone has information that is 'private or personal'; (ii) to which he or she could properly deny access to third parties; and (iii) he or she reasonably intended to profit commercially by using or publishing that information, then a third party who is, or ought to be, aware of these matters, and who has knowingly obtained the information without authority, will be in breach of duty if he uses or publishes that information to the detriment of the owner.

Since *Douglas*, a stream of cases has followed, and arguably the doctrine of confidence is now evolving into the nearest thing the legal systems of the UK have to a common law of 'privacy', albeit relating primarily to the control of the exploitation of one's personality or image. Yet the exact nature, and even the existence, of this right in UK law is much contested.⁹ Indeed in *Campbell v MGN*, the tort was rechristened by Lord Nicholls as 'misuse of private information' and his Lordship commented that that it was time to recognise that 'the values enshrined in articles 8 and 10 are

Marper v UK Applications 30562/04 and 30566/04, 4 December 2008 (not legal to retain DNA samples of suspects on police database). It seems privacy and DP issues are now as likely to arise at Strasbourg as at the ECJ in Luxembourg.

⁷ The law of confidence will not be explored in full in this chapter. See for a recent account of how the law of confidence has been extended in the UK to protect the privacy (and revenues) of, in the main, celebrities, see ch 18 of H MacQueen, C Waelde and G Laurie, *Contemporary Intellectual Property: Law and Policy* (Oxford, Oxford University Press, 2007).

⁸ [2005] EWCA Civ 595.

⁹ See in particular, *Campbell v MGN* [2002] EWCA Civ 1373 (Ct App); [2004] UKHL 22, (HL); *McGregor v Fraser* [2003] EWHC 2972; *Ash v McKennit* [2005] EWHC 3003 (QB); *Murray v Big Pictures* (UK) Ltd [2008] EWCA Civ 446.

now part of the cause of action for breach of confidence'.¹⁰ The decision also formalised a new two-step test for an actionable tort of this kind depending on whether (i) the information disclosed was private and not public; and (ii) whether disclosure of the information about an individual ('A') would give substantial offence to A, assuming that A was placed in similar circumstances and was a person of ordinary sensibilities (paragraph 92).

One key problem is that privacy has traditionally been thought of as a right to protect one's personality and preserve one's autonomy, in the non-economic context of human rights. These modern confidence cases, however, seem often to involve invoking the law of privacy in a bid to commoditise one's image rather than to protect a right of seclusion. It remains unresolved if the English courts wish to provide celebrities with essentially a new intellectual property right over their 'image' or 'brand' with which a new revenue stream can be properly secured, as is the case in states such as New York where 'publicity rights' statutes exist;¹¹ or if they merely wish to correct egregious interferences into what is clearly some form of private life by an intrusive tabloid press¹²—which is already encouraged if not mandated by the ECtHR.¹³ Is privacy just another commodity that should be bought and sold?¹⁴

Another problem is whether such a right of whatever purpose or scope is compatible both with the public's right to 'know', the media's right to report on news, and general rights of freedom of expression, eg of partners or friends.¹⁵ Note also that an act of disclosure of private information may be a breach of both DP law, and the law of confidence; this was true, for example, in *Campbell v MGN*,¹⁶ where photographs published of Naomi Campbell the supermodel, indicating that she was attending Narcotics Anonymous, gave rise to claims for infringement of both regimes.

Privacy may, of course, also involve *physical* or bodily privacy—the right not to be touched or in some way acted on against your will. This area of law is generally protected in the UK under existing laws such as the criminal law of assault or rape, or even under medico-legal laws such as the laws about abortion. In some cases where the law presents no obvious remedy, the ECHR has been invoked to provide one. In *Wainwright v United Kingdom*,¹⁷ for example, the ECtHR held that an unduly intrusive

¹⁰ *Campbell*, HL, above n 9, paras 14 and 17, respectively.

¹¹ See eg *Douglas v Hello!*, above n 8.; cf *Ash v McKennit*, above n 9.

¹² See for eg *Murray*, above n 9.

¹³ See *Von Hannover v Germany*, App No 59320/00, European Court of Human Rights, 24 June 2004.

¹⁴ On this commodification of privacy argument, see an excellent account by C Prins, 'When Personal Data, Behavior and Virtual Identities Become a Commodity: Would a Property Rights Approach Matter?' (2006) 3(4) *SCRIPT-ed* 270, available at: <http://www.law.ed.ac.uk/ahrc/script-ed/vol3-4/prins.asp>.

¹⁵ See in particular *Campbell v MGN*, above n 8 and *Ash v McKennit*, above n 8.

¹⁶ Above n 9.

¹⁷ Application No 12350/04.

strip search of relatives visiting a prisoner in jail had been a violation of Article 8 ECHR, even although the searches had been carried out in accordance with UK law.

In this section we will concentrate on informational or data privacy through the lens of European and UK DP law. This is a highly complex area full of legal minutiae: in the space allowed, it is not possible to go into comprehensive detail and several excellent books aimed at either or both of students and practitioners can fulfil that task.¹⁸ Instead this introduction has concentrated on key notions such as personal data, consent and the eight basic DP principles. In particular, the chapter does not describe the practical formalities of registration or 'notification' required of data controllers, nor does it deal in detail with exemptions from DP law or sanctions for breaches of DP law, important though both these areas are.

II. DATA PROTECTION LAW

Informational privacy as a concept has its origins in the combination of fear for individual privacy in the era of World War II, Nazism and the rise of Stalinism; and the emergence of widespread automated data processing. The pressing fear in Western states as the world rebuilt in the 1940s and 1950s was of the total surveillance 'Big Brother' state that had been glimpsed in Germany and the Soviet bloc. DP legislation thus began in Hesse in Germany in 1970¹⁹ and was first harmonised as a model European regime by the Council of Europe Convention of 1981.²⁰ It has since been adopted as mandatory law in the EU in the shape of the European DPD.²¹ Rooted in the ECHR's guarantee of a human right to private life in Article 8, DP law was clearly intended to protect the privacy of individual citizens against the state, and therefore, with some small exceptions, protects neither the deceased nor juristic persons (companies and similar unincorporated associations).

At the international legal level, as well as the ECHR and the 1981 Coun-

¹⁸ See eg P Carey, *Data Protection: A Practical Guide to UK and EU Law*, 3rd edn (Oxford, Oxford University Press, 2009); R Jay and A Hamilton, *Data Protection Law and Practice*, 3rd edn (London, Sweet & Maxwell, 2007). Detailed student coverage of the area can be found in I Lloyd, *Information Technology Law*, 4th edn (London, Butterworths, 2004). LA Bygrave, *Data Protection Law: Approaching its Rationale, Logic and Limits* (Information Law Series 10, 2002) 116 is an excellent review of DP from a more critical academic angle, and C Kuner *European Data Protection Law*, 2nd rev edn (Oxford, Oxford University Press, 2007) is an excellent account from a European and corporate compliance perspective.

¹⁹ See further the detailed history of DP law in Rauhofer, ch 17.

²⁰ EC: 108th Convention for the protection of individuals concerning automatic processing of personal data (1981). For a more detailed account of the historical origins of DP law, see Rauhofer, *ibid*.

²¹ Directive 95/46/EC of the European Parliament and of the Council of 24 October 1995 on the protection of individuals with regard to the processing of personal data and on the free movement of such data.

cil of Europe treaty, the Universal Declaration of Human Rights (UDHR),²² the International Covenant on Civil and Political Rights (ICCPR)²³ and the 1980 OECD Guidelines on the Protection of Privacy and Transborder Flows of Personal Data,²⁴ all enshrine the right to private life²⁵ and have all contributed to the creation of modern DP law.²⁶

A. The Coming of the Information Society and the Post-9/11 World: Their Impact on DP Law

In the 1940s and 1950s, state collection and processing of personal information was achieved via pre-digital bureaucratic methods, such as census information gathering, monitoring of internal passports, organisation of data in paper files, and human surveillance (as in East Germany, where anecdotally during the Cold War one in three citizens was in the employ of the secret police as an informer). From the late 1960s on, however, a new factor emerged: the arrival of the modern digital computer. The rise to prominence of DP law in recent times is generally attributed to the increasing use of computers and electronic communication devices.²⁷ Works such as Garfinkel's *Database Nation*²⁸ and, more recently, Solove's *The Digital Person*²⁹ have publicised the idea that we are now, by virtue of information technology, especially data mining, ubiquitous electronic surveillance, and local and global data sharing, 'sleepwalking into a surveillance society'.³⁰

Computerisation and digitisation allow collection, processing and storage of personal data on a scale unprecedented in the analogue era. Huge amounts of digitised data can be stored in principle for ever at relatively low cost, be searchable in minutes or seconds, not hours, by a vast number of criteria, and be further processed in limitless numbers of useful ways. Crucially, data collected from one source (or one 'database') can be combined with other databases, to generate new data revealing significant

²² GA res 217A (III), UN Doc A/810 at 71 (1948).

²³ GA res 2200A (XXI), 21 UN GAOR Supp (No 16) at 52, UN Doc. A/6316 (1966), 999 UNTS 171, entered into force 23 March 1976.

²⁴ Available at http://www.oecd.org/document/18/0,2340,en_2649_34255_1815186_1_1_1_1,00.html.

²⁵ See respectively Art 12 UDHR, Art 17 ICCPR, Art 8 ECHR.

²⁶ See again further discussion in Rauhofer, ch DP4.

²⁷ Carey, 2nd edn, above n 18, 1.

²⁸ S Garfinkel, *Database Nation: the Death of Privacy in the 21st Century* (Sebastopol, CA, O'Reilly, 2000). See also J Rosen, *The Unwanted Gaze: the Destruction of Privacy in America* (Vintage Books, 2001).

²⁹ DJ Solove, *The Digital Person: Technology and Privacy in the Information Age* (New York, New York University Press, 2004).

³⁰ See the Surveillance Studies Network, 'Report on the Surveillance Society', ICO, September 2006, para 11.3.3, available at http://www.ico.gov.uk/upload/documents/library/data_protection/practical_application/surveillance_society_full_report_2006.pdf ('Surveillance Society'). The exact quote was uttered by Richard Thomas, UK Information Commissioner, at an official engagement.

connections and comparisons—the concept of ‘data mining’. ‘Profiling’—looking for patterns in the data collected or aggregated about a person, or group of persons—has become increasingly ubiquitous. (The issues of profiling are discussed extensively in the context of the online marketing sector in chapter 16.)

Data held in databases for indefinite periods may also be reused for functions quite different from the purposes for which they were originally collected: this is the concept of ‘function’ or ‘scope creep’. Thus data collected about a person for medical purposes—eg a positive test for HIV—might theoretically later be used to categorise that person as a risk when he seeks life assurance, or permanent employment. DP law tries to combat these undesirable results (in terms of personal privacy) by introducing restrictions both on *how long* data can be retained, and crucially on ‘fishing’—collecting data for no particular *purpose*, or for extremely wide purposes, and using it as and when desired. Given the technical scope of modern computer storage and database technology, and the flimsy enforcement of data protection in practice,³¹ however, ‘scope creep’ may in practice be almost impossible to control. Indeed, Bennett and Raab³² suggest that it is one of the key hallmarks of the modern bureaucratic society that information *will* be collected just because it can be—to serve as a valuable potential commodity for the unknown future and for risk management. Rauhofer has labelled this ‘the dream of the risk-free society’³³ where the hope is that if enough data is collected, any future risk can be predicted and averted. Such trends are not only counterintuitive, but worrying for all data subjects, especially today’s children, who may perhaps have to grow up with the weight of data collected when they were too young to know about it metaphorically hung round their neck.

Digitisation is of course only one step in the transformation of the personal data world. The Internet has created a world in which data can be accessed ubiquitously and flows untrammelled across political frontiers. This creates almost impossible problems of audit and control from a data privacy perspective. Since different laws govern rights of privacy and confidentiality in different countries, export and import of personal data may involve loss or gain of privacy rights. How to deal with the impact of different jurisdictions on DP rights remains an opaque and politically thorny issue, as seen in the US/EU ‘safe harbour’ dispute, which we discuss below.

These problems of digitisation and transglobal data flows have combined with recent historical events to create a climate of fear among privacy

³¹ See below, p 467.

³² C Bennett and C Raab, *The Governance of Privacy*, 2nd edn (Boston, MA, MIT Press, 2006) 19–20.

³³ J Rauhofer, ‘Privacy is Dead—Get Over It: Art 8 and the Dream of a Risk-free Society’, 2nd GikII Workshop, 2007, UCL, London.

activist groups that we are losing our privacy by degrees. Many civil society groups already argue that rights such as privacy and freedom of expression are simply not as well protected on the Internet as they were in conventional media.³⁴ The post-9/11 approach to dealing with the threat of global terror has arguably disrupted the traditional balance struck between state security and fundamental values of privacy, and that balance may have tipped unduly in the direction of security, especially online.³⁵ The UK of all of the EU states has in particular been accused of steamrolling privacy in the pursuit of law enforcement and risk management, as well as streamlining governmental functions. The drive towards 'joined up' government initiated by Tony Blair has created a culture of building large, multiple-access databases to solve every social problem; these databases have so far invariably proved to be expensive, insecure and of questionable efficacy.³⁶ As *The Independent* summarised its cover story of 18 April 2009, 'Internet Privacy: Britain in the Dock.'

This leads us to a final key consideration arising from digitisation and the 'database society', ie data security. It is reasonably obvious if data held in handwritten files has been amended, or if the physical data store (an office, a filing cabinet) has been broken into; it is less obvious when data lives intangibly on a hard disk, laptop or CD. In recent years, public interest in DP, commonly seen in the past as detailed, nerdish and obscure,³⁷ has been fuelled by a deluge of reports of data leakage on an extravagant scale. While in North America, the worst data leakage scandals have tended to come from the private sector, eg Choicepoint in 2005³⁸ and TJ Maxx in 2007, in the UK the greatest anxiety has followed the loss in October 2007 by Her Majesty's Revenue and Customs (HMRC) of data relating to 25 million people seeking child benefit—almost half the inhabitants of the country.³⁹ The data, which included names, addresses, dates of birth, bank account details and National Insurance numbers, was placed on

³⁴ Prominent civil society organisations include EPIC, the Electronic Privacy Information Centre in the US; and FIPR, the Federation for Internet Privacy Research in the UK. See on the Internet and its threat to freedom of expression elsewhere in this volume, Edwards, chs 1 (ISPs) and 20 (pornography).

³⁵ Again, see a more detailed discussion of the crisis in privacy vs security in Rauhofer, ch DP4 and DP5.

³⁶ See also the influential report, 'Database State' (Joseph Rowntree Trust, April 2009) available at <http://www.jrtrt.org.uk/>, which surveyed 46 public-sector databases and argues that a quarter of all government databases are breaking DP law.

³⁷ See C Pounder, editorial, [2007] *Out-Law* 26 November, at <http://www.out-law.com/page-8663>: 'Isn't it sexy to be a data protection officer now? The staggering revelations of security breaches at HMRC have propelled data protection out of shadowy domain of geeks and anoraks, and into the bright sunlight of public debate.'

³⁸ See the useful chronology of data breaches and losses at <http://www.privacyrights.org/ar/ChronDataBreaches.htm>.

³⁹ See data compiled at http://en.wikipedia.org/wiki/2007_UK_child_benefit_data_misplacement.

an unencrypted CD by a junior official, sent using an insecure courier, and simply 'lost in the post'.

Subsequent revelations that have emerged in the wake of a government inquiry⁴⁰ and press and Information Commissioner pressure have included the loss of details of 600,000 military personnel via a laptop stolen from a car in Birmingham, the admission by the Ministry of Defence that 420 such laptops have been lost since 2003, and the loss of the records of 3 million learner drivers.⁴¹ The full fallout of 'ChildBenefitGate' has yet to be quantified, but immediate results in the UK are likely to include a renewed public concern for, and awareness of, privacy breaches; and new and more effective enforcement powers for the Information Commissioner.⁴² In a brutally critical report, the Joint Committee on Human Rights concluded that 'The fundamental problem is a cultural one: there is insufficient respect for personal data in the public sector.'⁴³ The government's own Poynter Report, issued in June 2008, agreed that 'information security at the time of the incident, simply wasn't a management priority' and that the incident was 'completely avoidable'. The effect on public confidence is starkly visible: in the February 2008 Eurobarometer report on attitudes to DP across Europe,⁴⁴ 77 per cent of data subjects in the UK reported they were very or fairly concerned about how their personal data was handled. This was one of the highest votes of no confidence in data handling in any EU state.

As more and more data is collected, created, compiled and stored, both in the private and public sector, the ability of individuals to know *what* data is held about them, and to *control* it, recedes. DP law aims, as we shall see below, to empower the data subject by giving them rights to find out what data is held about them and how it is being processed, to correct it if it is wrong, and most importantly, to say yes or no to collection of data *ab initio*.

⁴⁰ See Poynter Review page at http://www.hm-treasury.gov.uk/independent_reviews/poynter_review/poynter_review_index.cfm.

⁴¹ See 'MoD Admits it Has no Idea What Was on 400 Stolen Laptops', *The Independent* 20 January 2008.

⁴² See below, p 468.

⁴³ See 'Government Must Take Data Protection More Seriously, Says Parliament Committee', *Out-law News* 18 March 2008.

⁴⁴ See Eurobarometer/European Commission Flash Report, February 2008, 'Data Protection in the EU: Citizen's Perceptions', http://ec.europa.eu/public_opinion/flash/fl_225_en.pdf; and 'Data Protection in the EU: Data Controller's Perceptions', at http://ec.europa.eu/public_opinion/flash/fl_226_en.pdf (Hereafter 'Eurobarometer').

III. KEY LEGISLATIVE INSTRUMENTS: INTERNATIONAL LEVEL

A. The Data Protection Directive

The DPD,⁴⁵ adopted in October 1995, is perhaps the most comprehensive and significant enactment on informational privacy in the world. The UK DPA, implementing the DPD, wholly replaces the previous 1984 Act. The DPD was extended to deal with technological challenges by the Privacy and Electronic Communications Directive (PECD)⁴⁶ as implemented in UK by the Privacy and Electronic Communications (EC Directive) Regulations (PECR)⁴⁷ in October 2003. The DPD aims at protecting the fundamental right to privacy but only where personal data is processed wholly or partly by automatic means or is included in a manual filing system.

Article 6 DPD lays down eight fundamental DP principles (implemented in Schedule 1 of the DPA):

1. Personal data shall be processed fairly and lawfully.
2. Personal data shall be obtained only for one or more specified and lawful purposes, and shall not be further processed in any manner incompatible with that purpose or those purposes.
3. Personal data shall be adequate, relevant and not excessive in relation to the purpose or purposes for which they are processed
4. Personal data shall be accurate and, where necessary, kept up to date.
5. Personal data processed for any purpose or purposes shall not be kept for longer than is necessary for that purpose or those purposes.
6. Personal data shall be processed in accordance with the rights of data subjects under the DPD.
7. Appropriate technical and organisational measures shall be taken against unauthorised or unlawful processing of personal data and against accidental loss or destruction of, or damage to, personal data.
8. Personal data shall not be transferred to a country or territory outside the European Economic Area, unless that country or territory ensures

⁴⁵ OJ L281, 23/11/1995, 0031–0050.

⁴⁶ 2002/58/EC. The PECD is currently going through a process of reform as part of the package of electronic communications laws known as the Telecoms Package. Reform is at time of writing deadlocked due to disagreement on one non-DP-related point but a final draft is expected to pass sometime in 2009. See Common Position adopted by the Council on 16 February 2009 with a view to the adoption of a Directive of the European Parliament and of the Council amending Directive 2002/22/EC on universal service and users' rights relating to electronic communications networks, Directive 2002/58/EC concerning the processing of personal data and the protection of privacy in the electronic communications sector and Regulation (EC) No 2006/2004 on consumer protection cooperation, Council document No 16497/1/08, available at <http://register.consilium.europa.eu/pdf/en/08/st16/st16497-re01.en08.pdf>.

⁴⁷ SI 2003 No 2426.

an adequate level of protection of the rights and freedoms of data subjects in relation to the processing of personal data.

In respect of Principle 1, the DPD sets out a number of conditions, only one of which need apply, before personal data can be processed.⁴⁸ The most significant of these threshold conditions is the consent of the data subject (see detailed discussion below). There is a stricter regime for specified categories of *sensitive personal data* wherein processing is only allowed by explicit consent of the data subject,⁴⁹ or, less frequently, under another exemption.⁵⁰

The rights of data subjects alluded to in Principle 6 include:

- (a) the right to access their own personal data without excessive delay or expense.⁵¹ This subject access right is, however, subject to a large number of exceptions, and in practice is used mainly in specialised contexts such as employment tribunals.
- (b) the right to control the *integrity* of data relating to them, including the right to rectify, erase or block the processing of data whose processing does not comply with the DPD;⁵²
- (c) the right to object⁵³ to the processing of their personal data,⁵⁴ but only in limited circumstances, eg where processing is likely to cause damage or distress and where personal data is used for direct marketing purposes;⁵⁵
- (d) the right not to be subject to a legally relevant decision based solely on the automated processing of data,⁵⁶ eg a decision to withdraw or refuse to extend financial credit must not be based solely on automated processing.

The transfer of personal data to third countries in conformity with Principle 8 is now provided for in Chapter IV of the Directive and was the most controversial part of the Directive during its passage. Article 25 states that transfers of personal data to third countries outside the EU may take place only if the third country in question ensures an 'adequate' level of protection, the adequacy of which must be assessed in the light of all the circumstances surrounding the data transfer.⁵⁷ Merely making a webpage accessible to anywhere in the world does not, however, constitute a transfer

⁴⁸ DPD Art 7.

⁴⁹ For exemptions and restrictions see DPD Art 13.

⁵⁰ DPD Art 8.

⁵¹ DPD Art 12(a).

⁵² DPD Art 12(b).

⁵³ DPD Art 14.

⁵⁴ DPD Art 14(a).

⁵⁵ See DPD Art 14(b), and Art 7(e) and (f). See full discussion of online marketing and consumer data privacy in Edwards, chs 15 and 16.

⁵⁶ DPD Art 15.

⁵⁷ DPD Art 25 (2).

of personal data to a third country, since a third party still needs to make the effort to seek access to that data; the data must be ‘pulled’ not just ‘pushed’.⁵⁸ If this were not so, the special regime of Chapter IV would in effect expand to apply to all data processing on the Internet.⁵⁹ The aim of this provision is simple: to make sure that data exported outside the EU is not then processed in ways completely contrary to the DP laws of Europe, resulting in EU citizens suffering harm. The problem becomes obvious when one considers that data about EU data subjects might, for example, easily be collected by a website business based in the US, transferred to data-miners in China or sold to spammers operating in the Phillipines, while DP law does not operate in any of these countries nor is there likely to be any real local equivalent protection.⁶⁰

At present, only a few non-EU countries, including Switzerland, Guernsey, Jersey, the Isle of Man and Argentina, have been accredited by the EU as providing ‘adequate’ protection. Canada has been accredited for certain categories of information. In the difficult case of the US, a special agreement was negotiated under which companies within the US can register to join what is known as ‘safe harbour’ if they agree to fulfil certain fair information practices, either by their own self-regulatory conduct, or by joining a privacy or trust seal association such as TrustE. Space precludes full discussion of the ‘safe harbour’ compromise in this chapter, but a full critique can be found in the second edition of this text in the chapter by Charlesworth.⁶¹ Charlesworth argues forcefully that safe harbour represents a crucial watering-down of the protection given to personal data on its exit from the EU, in particular in relation to enforcement of safe harbour by trust seal bodies, an attitude espoused by many legal commentators, both European and North American.⁶² It is noteworthy that the European Commission’s review of safe harbour in 2004 also expressed considerable dissatisfaction with the privacy safeguards offered by safe harbour companies in practice.⁶³ Busch, a political scientist, however, inter-

⁵⁸ See *Lindqvist*, discussed below n 87, at paras 56–72.

⁵⁹ Above, para 69.

⁶⁰ Note DPD Art 4 which provides that EU DP law is asserted to apply, regardless of the nationality of the data controller, where processing is carried out in an ‘establishment’ in an EU country, or where there is no such establishment but ‘equipment’ is used for processing which is situated in a Member State. Leaving aside the vagueness of the key terms above (is a telephone line equipment? Is a cookie placed on a user’s hard disk?) in effect enforcement of these rules against non compliant extra-EU data controllers is mainly theoretical.

⁶¹ A Charlesworth, ‘Data Privacy in Cyberspace’, in L Edwards and C Waelde (eds) *Law and the Internet*, 2nd edn (Oxford, Hart Publishing, 2000). The latest safe harbour rules and other information, including which companies have signed up, can be found at <http://www.export.gov/safeharbor/>.

⁶² See eg testimony of Joel Reidenberg at Hearing on the EU Data Protection Directive: Implications for the US Privacy Debate, 8 March 2001, at http://reidenberg.home.sprynet.com/Reidenberg_Testimony_03-08-01.htm.

⁶³ Noting that, for example, less than a quarter of the companies signed up to safe harbour had privacy policies on their site expressly containing all seven safe harbour principles—a crucial requirement. See Commission Staff Working Document, 20 October 2004.

estingly prefers to view 'safe harbour' as a successful and pragmatic political compromise.⁶⁴

In all other cases, transfer of personal data outside the EU is in principle banned, but in practice can be achieved lawfully by obtaining the consent of the data subject to the transfer, or by the use of special contractual clauses which have been vetted by the EU authorities.⁶⁵ In practice, the number of companies signed up to 'safe harbour' declined after the glory days of the dotcom boom around the turn of the millennium, and the number now accredited is, though not negligible, so few compared to the total number of US companies as to make safe harbour look increasingly like a dead letter.⁶⁶ Instead, now the EU has approved model contractual conditions for 'private export' of personal data, it seems this is the preferred route for legitimate data export to the US and elsewhere, notwithstanding the questionable protection this gives European consumers post-export.⁶⁷ Some companies are now also exploring the use of Binding Corporate Rules to satisfy Article 26.⁶⁸

IV. NATIONAL LEVEL

A. The Data Protection Act 1998

The UK DPA came into force on 1 March 2000. The UK system is policed by the Information Commissioner's Office (ICO), which has issued

⁶⁴ See A Busch, 'From Safe Harbour to the Rough Sea? Privacy Disputes across the Atlantic' (2006) 3(4) *SCRIPT-ed* 304, at <http://www.law.ed.ac.uk/ahrc/script-ed/vol3-4/busch.asp>.

⁶⁵ See DPD Art 26, and the European Commission Decision of 27 December 2004, amending Decision 2001/497/EC as regards the introduction of an alternative set of standard contractual clauses for the transfer of personal data to third countries (notified under document number C(2004) 5271). See OJ L 385, 29/12/2004, 0074–0084. Those model clauses can be found at <http://www.privacydataprotection.co.uk/documents>.

⁶⁶ In 2004, 493 members were listed. In 2008, this number does seem to have roughly quadrupled but it is still remarkably low compared to the total number of US companies dealing in personal data. This rise can probably be related to the revival in fortune of the IT sector and Web 2.0. Notable safe harbour members include Facebook and Google. See, however, J Cline, 'Roadmap for an International Safe Harbor Framework' (2006) *International Review of Law Computers & Technology* 361, who, while acknowledging the criticisms of the safe harbour EU-US model, attempts to reform the basic concept as a model generally for international data flows out of the EU. Interestingly, his suggestion is that this model be negotiated within the WTO and include a dispute-resolution mechanism run by the WTO.

⁶⁷ 'Safe harbour' has if anything more explicit post-transfer safeguards for data subjects built in to the regime than does transfer of data by contractual conditions; yet safe harbour itself was trenchantly criticised on its compliance record, eg repeated scandals relating to misuse of personal data by prominent TrustE members such as Microsoft, Yahoo! and GeoCities. See Charlesworth, above n 61.

⁶⁸ See for the UK, ICO guidance at <http://dataprotectionthinker.blogspot.com/2005/12/binding-corporate-rules-scheme-ge.html>.

extensive legal guidance on the interpretation of the DPA,⁶⁹ the principles and related issues.⁷⁰ Data protection is a UK-wide matter reserved to Westminster. However, a Scottish Information Commissioner also exists who has a role in relation to Scottish DP interests as well as policing the separate Scottish Freedom of Information (FOI) scheme.

The DPA, like the DPD, uses certain specific and important terminology, most of which is defined in section 1(1) of the Act and is paraphrased here.

- ‘*Data*’ means information which is processed wholly or partly by means of equipment operating automatically, *or* is recorded with the intent that it should be processed by this equipment, *or* is recorded as a part of a relevant manual filing system.⁷¹
- ‘*Data controller*’ is the person, natural or juristic, who determines the purpose and manner of the data processing. Most duties in the DPA are placed on data controllers.
- ‘*Data processor*’ is the person who processes the data on behalf of the data controller, eg a data warehouse or batch processing mainframe. Data processors in this technical sense are relatively unimportant in the DPA scheme of duties.⁷²
- ‘*Data subject*’ is the living person who is the subject of the personal data.
- ‘*Personal data*’ is any information which relates to a natural person (the data subject) who can be identified or is identifiable from that data, directly or indirectly. The DPD definition in Article 2 gives examples of personal data as including an ‘identification number’ and ‘one or more factors specific to [the data subject’s] physical, physiological, mental, economic, cultural or social identity’. The DPA definition is slightly different in that it specifies in relation to ‘indirectly’ that this includes the case where the person cannot be identified by the information alone, but can be when it is combined with other data ‘likely’ to be held by data controller. This test of likeliness is not found in the original DPD definition.

What constitutes personal data is one of the central causes of doubt in the DP regime, both in the EU generally and in the UK specifically.⁷³

⁶⁹ See ICO, ‘Data Protection Act 1998: Legal Guidance’, available at http://www.ico.gov.uk/upload/documents/library/data_protection/detailed_specialist_guides/data_protection_act_legal_guidance.pdf.

⁷⁰ See ICO, Data Protection document library, available at http://www.ico.gov.uk/tools_and_resources/document_library/data_protection.aspx.

⁷¹ See interpretation of ‘relevant filing system’ in *Durant v FSA* [2003] EWCA Civ 1746, Court of Appeal (Civil Division).

⁷² Note the Art 29 Working Party *Opinion in the SWIFT Case*, Opinion 10/2006 (WP 128), 6 December 2006, which determined that SWIFT, a Belgian-based clearing house for international bank transfers made at the instruction of various EU banks, was not a mere data processor but had sufficient independent capacity to be regarded as a data controller, and was thus subject to the full rigour of Belgian DP law.

⁷³ The ICO issued new guidance for organisations on identifying personal data in February 2009: see http://www.ico.gov.uk/upload/documents/library/data_protection/detailed_specialist_guides/what_is_data_for_the_purposes_of_the_dpa.pdf.

The definition is crucial, because it is a threshold requirement to the application of any of the DP rules. Yet studies have shown in the past that there is a wide variation across the EU as to how the phrase is interpreted both in law and in practice.⁷⁴

The definition of personal data in the UK was significantly limited by the case of *Durant v FSA*⁷⁵ in 2003. In that case, the court held that:

Mere mention of the data subject in a document held by a data controller does not necessarily amount to his personal data. Whether it does so in any particular instance depends on where it falls in a 'continuum of relevance or proximity' to the data subject as distinct, say, from transactions or matters in which he may have been involved to a greater or lesser degree.

The court added that if the data was 'biographical in a significant sense, that is, going beyond the recording of the putative data subject's involvement in a matter or event that has no personal connotations', then it is likely to be regarded as 'personal data'.⁷⁶

This definition has proved controversial and is currently, it appears, being challenged in the European Court of Justice by the European Commission itself. In some contexts, it might conceivably be highly restrictive—eg in a record of activities made by closed-circuit television (CCTV), pictures of A, a passer-by, might not be regarded as 'personal data' of A if the focus of the camera was not intentionally on A, but on, say, persons going into a shop nearby. This might mean that the rules of fair processing were not applied to those pictures from the moment they were captured, although such rules would cut in if the pictures of A were later specifically processed with intent to identify or otherwise affect A's rights.⁷⁷

The Article 29 Working Committee, whose job is to deliver opinions on crucial and disputed areas of DP law in an attempt to secure European harmonisation, has reported recently on the definition of personal

⁷⁴ See the excellent pan-EU survey commissioned by the ICO, 'What Are Personal Data?', Sheffield University, 2004, available at http://www.ico.gov.uk/upload/documents/library/corporate/research_and_reports/final_report_21_06_04.pdf.

⁷⁵ Above n 71. The meaning of personal data in the context of anonymised medical data was also discussed in the Scottish FOI case, *Common Services Agency v Scottish Information Commissioner* [2006] CSIH 58 at <http://www.scotcourts.gov.uk/opinions/2006CSIH58.html>. The Scottish judgment was reversed by the House of Lords in [2008] UKHL 47 but their Lordships declined to comment on *Durant* as part of the binding opinion, regarding it as irrelevant to the issue of effective anonymisation at hand.

⁷⁶ *Durant v FSA*, above n 71, para 28.

⁷⁷ See discussion of this point in L Edwards, 'Taking the "Personal" Out of Personal Data: *Durant v FSA* and its Impact on the Legal Regulation of CCTV' (2004) 1(2) *SCRIPT-ed*, at <http://www.law.ed.ac.uk/ahrb/script-ed/issue2/durant.asp>. See also ICO, 'Data Protection Technical Guidance, Determining What is Personal Data' (21 August 2007), which in an apparent bid to limit the narrowing of the scope of personal data in *Durant*, suggests that the *Durant* test need only be consulted if data is not 'obviously about' or 'linked to' an individual. It is believed this guidance was a direct response to EU criticism in the Art 29 Opinion on Personal Data, cited in n 78 below.

data,⁷⁸ partly in response to the *Durant* controversy, but also to address the problem of whether DP law applies to certain data collected online which may not look like ‘traditional’ personal data, but the processing of which has the potential seriously to invade personal privacy. This could include information such as a user’s web traffic collected by an advertiser, or search terms collected by an engine such as Google (see discussion of both these cases in chapter 16). The key issue in these kind of cases is whether an IP address is ‘personal data’. IP addresses are simply a string of numbers which uniquely identify a computer, but only at a particular time; they do not in theory identify a person (many people in the household may use that machine) or even a particular machine on a permanent basis (most consumers sign up to domestic ISPs which dynamically assign and reassign IP addresses according to demand; thus an IP address can normally only identify even a household in conjunction with date and usage logs held by the ISP).

The controversy is important because information society service providers, including search engines, use IP addresses to connect the extensive data they collect and store about users—eg what search terms they enter, what results they click on—to a particular user or household. If IP addresses, held in conjunction with this search data, are defined as ‘personal data’, then Google (or business partners) are restricted in what they can do with it by the DP regime (so long as they operate in Europe⁷⁹). In particular, until recently Google retained all such collected data for almost indefinite lengths of time. If DP law applied, however, it would suggest that such data should be retained only as long as necessary to fulfil the purposes for which it was collected. Under pressure from the EU authorities, in 2007 Google agreed to reduce the maximum length of retention to 18–24 months.⁸⁰ In DP terms, this is still controversially long.

Google argued, however, that ‘the concept of personal data should be defined pragmatically, rather than upon the likelihood of identification’. Whether IP addresses were personal data should be dealt with on a case-by-case basis, depending on the context and the practicality of identification of a data subject.⁸¹ The Article 29 Working Party report of

⁷⁸ Art 29 Working Committee *Opinion 4/2007 on the Concept of Personal Data*, 20 June 2007, WP 136.

⁷⁹ See Art 29 Working Party *Opinion on Data Protection Issues Related to Search Engines*, 4 April 2008, WP 148, which inter alia, discussed the obvious jurisdictional objection that Google is based in the US not Europe. However, the Report clearly asserted that the DPD *does* clearly apply to search engines which deposit cookies on the machines of EU-resident users, even if the search engine is based economically or physically outside the EU (see DPD Art 4(1)(a).) See also the earlier WP 56 of 2002, available at http://ec.europa.eu/justice_home/fsj/privacy/docs/wpdocs/2002/wp56_en.pdf

⁸⁰ See public letter from Schaar, chair of the Art 29 Working Committee to Peter Fleischer, Privacy Counsel of Google, 16 May 2007.

⁸¹ See ‘Are IP Addresses “Personal Data”??’, Peter Fleischer’s blog, 5 February 2007.

2007, however, drew attention to recital 26 of the DPD, which provides that 'to determine whether a person is identifiable account should be taken of *all the means likely reasonably to be* used either by the controller or any other person to identify the said person' (original italics). From this they concluded that the 'test is a dynamic one and should consider the state of the art in technology at the time of processing and the possibilities of development during the period for which the data will be processed'. In 2008, the Working Party went further and issued a dedicated report on search engines and DP, in which they reiterated that, in most cases, IP addresses have to be seen as person-related, and therefore to be safe data controllers must assume they fall within the DPD.⁸²

Thus, the EU certainly seems to feel that Google (and other online data collectors using IP addresses or similar as unique identifiers) must respect European DP law when they capture data from EU-based citizens—and in particular must respect the limits DP law places on data retention.⁸³ How to enforce such an assertion is a more political matter, however.

- 'Sensitive personal data' is a subset of personal data which is regarded as so intensely personal that special safeguards are needed to guard against abusive processing. As defined in the DPD Article 8 and subsequently incorporated into the DPA, section 2, sensitive personal data means data relating to race, political opinions, health and sex life, religious and other beliefs, trade union membership and criminal records. These categories betray their historical and cultural origins in Europe in the 1980s and arguably exclude some important and valued types of personal information in twenty-first century Britain, eg there is no mention of biometric information such as fingerprints, retinal scans or DNA profiles (or the samples themselves⁸⁴), or of financial details such as credit card data. Nor is there any consideration of the subject of the data: it might be argued that *all* data disclosed by a child, for example, is 'sensitive'.⁸⁵ Wong⁸⁶ points out that following the ECJ decision in

⁸² See comment by Shaar reported in *Out-law.com* at 26 February 2008 on the Art 29 Working Party Opinion, below n 83.

⁸³ See further Art 29 Working Party *Opinion on Data Protection Issues Related to Search Engines*, 4 April 2008, WP 148. Interestingly the WP did not declare that the Data Retention Directive (see further ch 18) applied to Google and other search engines—hence only the basic DP rules found in the DPD relating to length of storage apply. The WP did, however, recommend a maximum retention period of six months for search engines.

⁸⁴ See D Beylveled and MJ Taylor, 'Patents for Biotechnology and the Data Protection of Biological Samples and Shared Genetic Data', in J Herveg (ed), *The Protection of Medical Data: Challenges of the 21st Century* (Anthemis, 2008) in which the authors argue interestingly if controversially that the physical DNA sample itself might be regarded as 'personal data' and hence subject to DP protection.

⁸⁵ Compare the US system, which lacks an omnibus regime such as DP law and has no general concept of 'sensitive personal data' but does have specific and highly regulated statutory privacy regimes for health, financial and children's data (HIPAA, Sarbanes-Oxley and COPPA).

*Lindqvist*⁸⁷ where a simple photograph of a woman with a note that she had had health problems was held to embody ‘sensitive personal data’, there is a danger that almost all personal images can be so categorised—eg a picture of a person must usually reveal their skin colour and thus something about race.⁸⁸ The special regime for sensitive personal data might thus be potentially extended to cover every picture on the World Wide Web, a consequence that was surely not intended. Arguably the concept of especially sensitive personal data is useful, but a more flexible or purposive system of classification might be desirable.

Certain conditions must be satisfied before sensitive personal data can be processed, on top of the conditions for processing of ordinary personal data: these are considered below, p 462.

- ‘*Processing*’ is very widely defined to include obtaining, recording or holding the information or data on the data subject, or carrying out any set of operations on the data, *including* organising, adapting, altering, retrieving, combining, consulting, using, disclosing, transmitting or disseminating it. It also covers blocking, erasing and destroying information or data.⁸⁹ In the leading ECJ case of *Lindqvist*, a Swedish woman set up a personal ‘home page’ on which she posted pictures of fellow members of her church along with some identifying details. It was held that she was indeed ‘processing personal data’ within the meaning of the DPD, even though the process was only partly automated by the use of web-serving software. Importantly, a defence that her activities were in the course of a non-profit-making or leisure activity and so fell outside Article 3(2) of the DPD (or as the UK DPA puts it, were for ‘domestic purposes’⁹⁰) was rejected. The Court considered that Mrs Lindqvist’s activities could clearly not be seen as carried out in private or in the course of her family life, since they involved publication of data on the

⁸⁶ R Wong, ‘Data Protection Online: Alternative Approaches to Sensitive Data?’ 2007(2) *Journal of International Commercial Law and Technology* 9, at www.jiclt.com/index.php/JICLT/article/view/28/15.

⁸⁷ *Lindqvist v Kammaraklagaren*, European Court of Justice, Case C-101/01, 6 November 2003.

⁸⁸ See further *Murray v Big Pictures (UK) Ltd* [2007] EWHC 1908 (Ch) where the first instance court noted *obiter* regarding a photo of JK Rowling’s (white) baby taken while the infant was wheeled through a public street, that ‘It seems to me that if a photograph and the information it contains constitutes personal data, then it is hard to escape from the conclusion that insofar as it indicates the racial or ethnic origin of the data subject it also consists of sensitive personal data.’ However under the DPA, Sched 3, r 5, the photographer was exempt from the special rules regarding sensitive personal data, as the child’s parents had exposed the child in public. The court, however, declined to consider that any image also necessarily conveyed *health* data as ‘A photograph of an apparently healthy individual in fact tells one nothing about his actual state of health’ (para 80).

⁸⁹ See, however, *Johnson v Medical Defence Union Ltd* [2007] EWCA Civ 26 for a case where an activity was *not* held to be ‘processing’ within the DPA scheme.

⁹⁰ See DPA s 36.

Internet to 'an indefinite number of people'.⁹¹

The implications of this case, which is often described as a 'highwater mark' of DP maximalism, have been much criticised. In principle it implies that every person who sets up a family photo page, every blogger who writes about her colleagues or friends online, every child or adult with a Facebook or MySpace page which displays friends' photos or details, every charity or civil society group which publishes a list of its members on a website, is processing personal data within the DPD and the UK DPA, and thus must abide by the complicated rules of the DP regime. These may (as in the UK) involve mandatory registration as a data processor, and potential criminal sanctions if this procedure is not followed. Many have argued this is an unnecessary incursion of bureaucracy into the quasi-domestic and certainly non-profit-making sphere,⁹² yet it is difficult to see where the line could be drawn in the shifting sands of the Internet where 'free' services are decidedly not always private or non-economic activities. However this author would argue that a website that is password-protected or 'friends-locked' (as is possible on many blog or social networking sites (SNSs)) is not made available to 'the public' and thus should fall within the 'domestic purposes' exemption. A better solution would be, it is asserted, to reconsider the DPD exemption in this area to better fit the reality of the user-generated content world and overrule *Lindqvist*. Certainly the Article 29 Working Party's latest opinion on social networking sites appears to regard the users of SNSs as primarily 'data subjects' not 'data controllers', but importantly *only* so long as they restrict access to their pages to a selected list of friends and hide their profiles from search engines.⁹³ As discussed below, it is, however, precisely these acts of 'privatisation' that are almost never set as default by the software of the SNS provider and it is well known that few SNS users ever change the default settings.

B. Fair Processing and Consent

The DPA incorporates word for word the eight data protection principles in the DPD noted above into Part I of Schedule 1 of the Act. Interpretative provisions which expand on the Principles 1, 2, 6 and 6–8 are set out in Part II of Schedule 1.

'Fair processing', as required under DP Principle 1, is a crucial notion in

⁹¹ *Lindqvist*, above n 87, para 47.

⁹² See eg R Wong, 'Social Networking: Anybody is a Data Controller!', BILETA Conference 2007, Glasgow Caledonian University; R Wong and J Savaramithu, 'All or Nothing: This Is the Question? The Application of Art 3(2) Data Protection Directive 95/46/EC to the Internet' (2008) 25 *John Marshall Journal of Computer & Information Law* available at http://papers.ssrn.com/sol3/papers.cfm?abstract_id=1003025.

⁹³ See Art 29 WP Opinion 5/2009 on online social networking, 12 June 2009, WP 163.

giving teeth to rights of privacy for data subjects. The best-known ground (though given no precedence in strict law) for rendering processing 'fair' is that the data subject has given their consent.⁹⁴ As we shall also see below, however, in the discussion of social networking sites such as Facebook, consent is increasingly failing to be an effective threshold condition in a world where users regularly accept standard term contracts to access online services, and effectively give away their personal data without consideration or safeguards.

Other important grounds than consent do exist to render processing 'fair',⁹⁵ eg that the processing is necessary for the performance of a contract to which the data subject is a party,⁹⁶ for the administration of justice,⁹⁷ to fulfil various legal obligations of the data controller,⁹⁸ and that it is necessary to protect the data subject's 'vital interests'.⁹⁹ One ground which is commercially relevant but sometimes controversial is that of DPA, Schedule 2, paragraph 6, which says that processing may be carried out if in the data processor's 'legitimate interests', so long as there is not 'prejudice to the rights and freedoms or legitimate interests' of the data subject. The terminal subclause is essential here, or any business person (eg an advertiser) could ride rough-shod over the privacy rights of individuals on the grounds that to do so was essential to his business. Traditionally this provision has been seen as setting up a balance between the interests of the business and the rights of the data subjects affected; however, the recent ECJ case of *Bavarian Lager*¹⁰⁰ interestingly suggests instead that where there is any incursion which truly affects the privacy of the individual data subject, rather than a balance, the business interest must give way.

In the case of sensitive personal data, the requirement of fair and lawful processing must be satisfied, but, in addition, at least one of a number of additional conditions must be satisfied.¹⁰¹ These include: that the data subject has given *explicit consent*; that processing is necessary to protect the vital interests of the data subject; that processing relates to data deliberately made public by the data subject;¹⁰² that processing is necessary for legal reasons (including obligations under employment law) or for the adminis-

⁹⁴ DPA Sched 2, para 1.

⁹⁵ DPD Sched 2.

⁹⁶ DPA Sched 2, para 2(a).

⁹⁷ DPA Sched 2, para 5(a).

⁹⁸ DPA Sched 2, para 3.

⁹⁹ DPA Sched 2, para 4.

¹⁰⁰ *Bavarian Lager v Commission of the EC*, 8 November 2007, Judgment of the Court of First Instance in Case T-194/04.

¹⁰¹ DPA Sched 3.

¹⁰² See further *Murray*, above n 88. This would interestingly seem to allow processing without *explicit* consent of sensitive data made available on social networking sites (SNSs), such as Facebook—good news both for SNS operators and for third parties such as direct marketers who often collect personal data from SNS pages. Note that *non* explicit consent (which might be collected via, eg, a privacy policy agreed to as part of registration with the site) would still be necessary, however, under ordinary Sched 1 rules. See further p 476.

tration of justice; that processing is necessary for medical purposes; that racial or ethnic data needs to be processed for equal opportunities monitoring. It can be seen that except in unusual circumstances such as litigation, the principal requirement for processing of sensitive data is likely to be 'explicit consent'.

So what is 'consent' and how does it differ from 'explicit consent'? Consent is one of the key concepts of DP law, yet, oddly, it remains undefined in the UK DPA (on the supposition that the nature of consent was well understood in our law). Within the DPD, Article 2 it is defined as 'any freely given specific and informed indication of his wishes by which the data subject signifies his agreement to personal data relating to him being processed'. This definition was not transposed into UK law. The ICO has, however, indicated in guidance that consent should be 'informed' and 'unambiguous'. The DPD definition of 'ordinary' consent should also be contrasted as something implicitly less rigorous than the (sometimes equally uncertain) requirement for 'explicit consent' for the processing of *sensitive* personal data.¹⁰³

Clearly, consent to the processing of 'ordinary' data can be *implicit*—eg drawn from facts and circumstances or actions. Consent can also be defined as '*opt out*' rather than '*opt in*'. In opt out, a person is asked only to make an indication if they do *not* consent or have decided to withdraw consent, eg 'Tick here if you do not wish your personal data to be shared with carefully selected third parties' (a formulation often seen on consumer websites). In opt in, however, the subject is asked to give prior consent before processing is undertaken. Opt in is usually seen as more protective of user privacy. In practice the distinction may not be so clear: on a website where a data controller seeks consent, there might alternatively be an opt-out box which is blank, or an opt-in box which is pre-ticked. Which of these, if either, gives the user the most practical protection? The law, meanwhile, mandates neither and the result is mainly public confusion.

In many situations, furthermore, consent will be given without any semblance of a 'freely given specific and informed indication of his wishes'. For example, many standard form employment contracts require employers to consent to employer surveillance of their workplace, their e-mails and their telephone calls from work. Few employees will actually read and understand such clauses, and even fewer will turn a job down rather than give consent, there being effectively no possibility of negotiating on such standard terms.¹⁰⁴ When one turns to children, the power differential be-

¹⁰³ Which requirement is explicitly implemented in UK law: see DPA Sched 3, para 1.

¹⁰⁴ Note, however, that Part 4 of the Employment Practices Data Protection Code issued by the ICO states that there must be no penalty imposed on the employee for saying no to the processing of sensitive personal data, and that if consent is provided, the employee must be able to withdraw that consent in the future. Part 4 of the Code also states that blanket consent, obtained at the outset of employment, 'cannot always be relied upon'.

tween a school demanding fingerprints as price of access to the library, or the canteen, and a child is obvious. Given the increased surveillance of children by parents, schools, the law and the state (see below), this is a crucial point.

Another problem with consent is: how *long* does it last? ICO guidance makes it clear that consent once given may not last forever. Combined with the rules restricting data retention, in most cases it seems reasonable to assume that both consent and data should last only as long as necessary for the processing, given the stated purposes of processing.¹⁰⁵ On the Internet, however (as we have already seen in the example of the Google cookie), indefinite retention often seems to be the norm; and as we discuss further in chapter 16 there are of course strong economic incentives to retain as much personal data as possible in commercial contexts where it can be monetised.

Guidance about how consent should be obtained can also be drawn from the other requirements in the DPA for ‘fair processing’. First, when considering if processing is ‘fair’, regard must be had to the method by which consent is obtained, eg it will not be ‘fair’ if the data subject was deceived or misled.¹⁰⁶ Secondly, the data subject giving consent must be given information as far as is practicable at the appropriate time about the identity of the data controller, and the *purposes* for which the data is being collected. In general, those purposes should be made public and specific in the register where UK data controllers are required to make an entry and which is available via the Information Commissioner’s website. However, these purposes are often specified in very broad terms, and do little to inform the public, or restrain unfettered data collection. For example, it is legitimate to say little more than that that data is being collected or processed for reasons such as ‘research’ or ‘education’.¹⁰⁷ Among private-sector data collectors, it is common to register so many categories of reasons for data collection that few, if any, categories of data will be left out whatever is collected. ‘Scope creep’—the use of data collected for one purpose for another purpose—is thus in reality rather easy.

Capacity to consent under the DPA is also related to age. In Scotland, the Act specifies that consent can be given by a child under 16 as soon as they have a ‘general understanding’ of what it means to exercise the right to give consent. A person aged 12 or over is presumed to be of sufficient age and maturity to have that capacity.¹⁰⁸ Below that age, consent should in

¹⁰⁵ See ICO Guidance, above n 69, para 3.1.5, 29–30.

¹⁰⁶ DPA Sched 1, Pt II, para 1(1).

¹⁰⁷ See R Anderson, I Brown et al, ‘FIPR: Children’s Databases–Safety and Privacy: A Report for the Information Commissioner’ (March 2006) available at http://www.ico.gov.uk/upload/documents/library/data_protection/detailed_specialist_guides/ico_issues_paper_protecting_childrens_personal_information.pdf (‘FIPR Report’).

¹⁰⁸ DPA s 66.

principle be given by the person or persons with parental responsibilities and rights.¹⁰⁹

In England, the situation is less clear. The ICO has not provided specific guidance and the Act is silent. In principle, drawing on the seminal child capacity case of *Gillick v West Norfolk and Wisbeck AHA*,¹¹⁰ it would appear that a child should have the ability to give consent to data collection or processing when they are of an age and maturity to understand the nature and consequences of exercising that capacity. This is the standard test for the giving of medical consent by a child without the consent (and in some cases, the knowledge) of their parent or guardian and has become known as 'Gillick-competence'. However as the writers of the FIPR Report on the Children's ID Database ('ContactPoint') have observed, the interpretation of *Gillick* is also not entirely straightforward, and there is a danger that a young child might be asked to consent against their best interests without the protective guidance of their parent(s). Again, if a child is not 'Gillick-competent', it seems DP consent should be given for the child by those with parental responsibilities and rights. The issue of who consents is germane because the UK is currently engaged in putting the details of millions of its children into databases, for purposes such as proactive social work involvement, youth justice and joined-up agency co-operation. Laudable though these purposes are, the net effect for children may be that they become the next 'database generation' without fully understanding what they (or their parents) have given away in terms of personal privacy.¹¹¹

C. Exemptions¹¹²

A number of important exemptions from and modifications to the DPA exist, either in the Act itself or in separate SIs. The exemptions in the DPA can be found in Part IV (sections 28–36) and Schedule 7. Some exemptions merely allow data controllers to ignore the fair processing and subject

¹⁰⁹ This arises from the general law relating to parental responsibilities and rights: see in Scotland the Children (Sc) Act 1995 ss 1 and 2. This rule is modified by specific rules in statutory instruments—eg the DP (Subject Access Modification) (Social Work) Order 2000/415 provides that a parent cannot make a subject access request on behalf of a child if it would be likely to prejudice the carrying on of social work by virtue of resultant serious harm to the child or another person. Similar rules exist in relation to health data (SI 2000/413) and education data (SI 2000/414).

¹¹⁰ [1985] 3 All ER 402.

¹¹¹ See general discussion in FIPR Report, above n 107. The ContactPoint children's database discussed in the report, and subject to repeated criticism since, nonetheless finally went live on 18 May 2009—see <http://news.bbc.co.uk/1/hi/education/8052512.stm>.

¹¹² The exact rules here are complex and too lengthy for this chapter—see further Carey, 2nd edn, ch 9.

access rights provisions,¹¹³ while others exempt the data controller from almost all DPA obligations.¹¹⁴

Most notably, not only law enforcement agencies, but anyone, even a private householder, who claims they are processing personal data in the 'prevention or detection of crime' is exempt from the fair processing and subject access rules.¹¹⁵ Thus a private shop-owner who sets up a CCTV camera to watch shoppers in case they are shoplifters or robbers need not obtain consent of data subjects but need merely give notice that there is a camera on premises. It is arguably for this reason that CCTV is so prevalent in the UK, and that cameras can be found not just in public but increasingly in residential areas where they are potentially highly intrusive of private life. National security is also an important exemption:¹¹⁶ in this case, however, a ministerial certificate must be obtained certifying that processing is for purposes of safeguarding national security.

The other principle exemptions are processing in the case of:

- regulatory activity;¹¹⁷
- journalism¹¹⁸, literature and art;¹¹⁹
- research, history and statistics;¹²⁰
- information made available to the public by or under enactment;¹²¹
- disclosures required by law and in connection with legal proceedings;¹²²
- domestic purposes;¹²³
- miscellaneous exemptions;¹²⁴
- armed forces;

¹¹³ Paras 2 and 3 of Part II of Schedule I of the Act (fair processing of information) and s 7, subject access.

¹¹⁴ The First Data Protection Principle, except where it requires compliance with the conditions in Sched 2 and 3 of the Act (the conditions for processing and conditions for processing sensitive data); the Second, Third, Fourth and Fifth Data Protection Principles; s 10 (right to prevent processing likely to cause damage or distress); and s 14(1)–(3) (rectification, blocking, erasure and destruction).

¹¹⁵ DPA s 29. Note that the EC has introduced a Framework Decision on the protection of personal data processed in the framework of police and judicial co-operation (Council Framework Decision 2008/977/JHA), 30 December 2008. However, the main point of this instrument is to enable greater data sharing between national EU police forces, not to increase the stringency of the treatment of data collected pursuant to the crime prevention exemption.

¹¹⁶ DPA s 28.

¹¹⁷ DPA s 31.

¹¹⁸ See discussion of the extent of the 'public interest' aspect of the journalism exemption in *Campbell v MGN* [2002] EWCA Civ 1373, cf *Douglas v Hello!* [2003] EWHC 786 (Ch) where the journalism exemption was not made available as publication was found not to be in the public interest, in the belief of the data controllers. Note also that the Art 29 WP 87 (above n 93) has indicated that the 'journalism' exemption may be open to amateur bloggers just as much as professional reporters.

¹¹⁹ DPA s 32.

¹²⁰ DPA s 33.

¹²¹ DPA s 34.

¹²² DPA s 35(1).

¹²³ DPA s 36. See discussion in relation to *Lindqvist*, above n 87.

¹²⁴ Sched 7, eg confidential references given by or to data controllers for specified purposes.

- exemptions contained within the Data Protection (Miscellaneous Subject Access Exemptions) Order 2000;¹²⁵
- orders made in relation to health, education and social work¹²⁶
 - Health (The Data Protection (Subject Access Modification) (Health) Order 2000;¹²⁷
 - Education (The Data Protection (Subject Access Modifications) (Education) Order 2000;¹²⁸
 - Social Work (The Data Protection (Subject Access Modifications) (Social Work) Order 2000.¹²⁹

In the Coroners and Justice Bill 2009, the UK government attempted to introduce a 'data sharing' provision which would have effectively allowed all public-sector departments to share personal data both between themselves and in certain circumstances with the private sector. Such a sweeping power would have effectively exempted much of the public sector from crucial DP safeguards, with particular fears as to disclosure of patient health data which might have breached the usual guarantees of medical confidentiality. In the face of severe public and professional criticism, the proposals were dropped in March 2009. They may, however, yet reappear.

D. Enforcement and Compensation

Enforcement is part of the role of the ICO. The policy of the UK DP regime has, however, historically been to encourage compliance from data controllers rather than simply to impose penalties. Data subjects are encouraged to complain of breaches to data controllers in the first instance, and data controllers themselves are encouraged to consult with the ICO and seek advice, with prosecution seen as a last resort if agreement cannot be reached as to compliance. Where it suspects a breach, the ICO is not allowed to immediately bring a prosecution, but must first serve either an information notice (asking the data controller to provide details of their processing activities), a 'special' information notice, or an enforcement notice (requiring the data controller to comply with specified DP principles). Only if these are insufficient to procure compliance can the ICO proceed to the courts. Failure to comply with any of these notices is a criminal offence. The ICO can also seek a warrant to exercise powers of entry, seizure of documents and equipment, etc.

As may be imagined from the above, prosecutions have been rare in the

¹²⁵ SI No 419. SI 2000 No 419 (as amended by The Data Protection (Miscellaneous Subject Access Exemptions) (Amendment) Order, SI No 1865.

¹²⁶ DPA s 30.

¹²⁷ SI 2000 No 413, also called the 'Health Order'.

¹²⁸ SI No 414, the 'Education Order'.

¹²⁹ SI No 415, the 'Social Work Order'.

past, and even if successful, sanctions are usually low. In theory, DP breaches in the UK can be punished by a maximum £5,000 fine on summary prosecution or an unlimited fine on indictment (section 60), but more commonly the results have been low fines or conditional discharges. Most prosecutions are for the relatively minor offences of failing to register (section 17) or notify changes as a data controller to the ICO (section 21) or, more seriously, for unlawfully selling or obtaining personal data (section 55). The ICO, hampered by significant underfunding as its workload has increased (despite being the largest privacy watchdog in Europe), has done little to pursue prosecutions as a rhetorical or symbolic gesture, generally taking on only small to medium-sized achievable targets, eg a recent offensive against the trade in personal information, bought by the likes of journalists and private detectives,¹³⁰ and against solicitors in particular¹³¹ for failing to register.

This ‘softly softly’ approach has entirely failed to make visible inroads against either the vast number of small-scale privacy breaches associated with the Internet, or the large-scale data breaches that have become prevalent in the last few years, especially in the public sector. Indeed the ICO stated in 2008¹³² that broadly it would focus its limited resources not on enforcement, but on reducing the risk to UK residents of misuse of personal information about them. The ICO also noted its intention to target the increasing surveillance of UK citizens. While laudable goals, these policy statements showed that DP enforcement was intended to be neither comprehensive nor generally deterrent in the same way as ordinary criminal prosecution.

Since these announcements, however, there has been a change of Information Commissioner and a public backlash against the enormous public sector data breaches mentioned earlier—both of which may now lead to increasingly punitive powers for the ICO. Notably, the ICO has already received the power to serve an assessment notice on a data controller, effectively allowing it to intervene ahead of a potential breach as an ‘audit’ body, and investigate whether DP principles are being adhered to.¹³³ Furthermore the Criminal Justice and Immigration Act 2008 introduced the power for the Information Commissioner to impose civil monetary penalties on data controllers who knowingly or recklessly commit serious contravention of the DP principles (including security)¹³⁴—ie fine those in breach without having to go to court, as regulators such as ICSTIS already can. Note, however, that negligent data breach remains excluded. Penalties

¹³⁰ See *What Price Privacy Now?* (ICO, May 2006) available at http://www.ico.gov.uk/upload/documents/library/corporate/research_and_reports/ico-wppnow-0602.pdf.

¹³¹ See ‘Lawyers Penalized for Data Protection Breach’, *OUT-LAW News* 21 February 2008.

¹³² *ICO Data Protection—Protecting People* (2008) available at http://www.ico.gov.uk/upload/documents/library/data_protection/detailed_specialist_guides/ico_dps_final.pdf.

¹³³ DPA 98 s 41A.

¹³⁴ S 144, inserting new s 55A into the DPA.

were also increased for the section 55 crime of unlawfully obtaining or trading in personal data by virtue of the Criminal Justice and Immigration Act 2008, section 77—including the possibility of a two-year jail sentence.

E. Mandatory Security Breach Disclosure

It is often suggested that in the corporate sector the bad PR caused by a disclosed data breach is a far more effective sanction than any given by the ICO or the courts. For this reason, among others, the EC is likely to regulate as part of the proposed reforms to the PECD that data breaches in some industry sectors should be subject to rules of mandatory public disclosure.¹³⁵ Data breach disclosure rules are already common in the US and in some other systems such as Japan. Their effectiveness, however, remains controversial, with some evidence of ‘notification fatigue’, and much of the devil is in the detail, eg how major must a security breach be before it needs to be notified? Who should it be notified to? What details should be notified? Who should determine the seriousness of the breach? Should notification go to every potential victim of a data breach, or just to a regulator or law enforcement agency? And what remedies should the public have in response to such a breach notification?

The draft European proposals at the time of writing propose that notification should be made, without ‘undue delay’, to the competent national authority (in the UK, the ICO) where the data breach ‘is likely to adversely affect the personal data and privacy of a subscriber as an individual’. A requirement of ‘severity’ may yet be also imposed, further restricting the scope of the provisions. It is then for the national regulator to decide whether to mandate disclosure to individuals affected (data controllers may voluntarily disclose more widely if they so please). No notification need be made if the data breached is encrypted and so ‘unintelligible’ to persons unauthorised to access it. The national regulator is to be empowered to audit the data controllers in breach to check they have met their obligations under the data breach notification regime, and impose sanctions if there is failure. ENISA, the European security agency, as well as the Article 29 Working Party will have a role in trying to impose some degree of harmonisation as these proposals are implemented across Europe.

These proposals, though still provisional, have already received severe criticism from both the Article 29 Working Party and the European Data Protection Supervisor.¹³⁶ Criticism has particularly focused on the limited

¹³⁵ See the revised PECD draft rules, above, n 46, draft revised Art 4, ‘Security of processing’.

¹³⁶ See Art 29 WP Opinion 1/2009 on proposals amending Directive 2002/58/EC, WP 159, 10 February 2009; Second Opinion of the EDPS on the review of Directive 2002/58/EC concerning the processing of personal data and the protection of privacy in the electronic communications sector, available at www.edps.europa.eu.

scope of the data breach proposals, which at present apply only to ‘publicly available electronic communication services’. This would include ISPs and telecoms companies such as BT and Orange, but not obvious sources of concern such as banks or financial institutions. The European Commission has provisionally agreed that there is no reason to limit the regime just because it has been introduced via telecoms reform; and has indicated it will extend the debate to general information society service providers, with a view to proposing legislation by the end of 2011. Commentators have also noted, however, that if regulators such as the ICO are already struggling to deal with their caseload, an avalanche of data breach notices will probably stretch their resources to breaking point; and that similar legislation in the US has failed to restrict the growth of identity theft and other data breach frauds.¹³⁷ Overall it seems unlikely that breach notification, though a positive step, will be any kind of panacea.

Data subjects who suffer loss as a result of breaches of DP law can seek compensation in a civil action in the UK courts under section 13(1) of the DPA. Damage must have occurred ‘by reason of’ a data controller’s contravention of a DPA requirement¹³⁸ and can be awarded for economic loss or distress (section 13(2)). Such claims are in practice extremely rare. This seems unsurprising given the general impediments to consumer litigation combined with widespread consumer ignorance as to DP rights and remedies.¹³⁹ The current lack of viable civil class action procedures in the UK is another key reason why security breach notification may still not lead to better redress for notified users whose privacy rights have been infringed.¹⁴⁰

V. DATA PROTECTION LAW AND THE FREEDOM OF INFORMATION ACT 2000¹⁴¹

The Freedom of Information Act 2000 (FOI) seeks to encourage open government and greater public accountability by facilitating access to infor-

¹³⁷ See S Romanosky, R Telang and A Acquisti, ‘Do Data Breach Disclosure Laws Reduce Identity Theft?’, 16 September 2008, draft available at http://papers.ssrn.com/sol3/papers.cfm?abstract_id=1268926, which found, comparing US states with a security breach disclosure law to those without, that such a law seemed only to reduce identity theft by 2 per cent on average.

¹³⁸ See *Johnson v Medical Defence Union* [2006] EWHC 321 (Ch) where the claim was not upheld.

¹³⁹ Eg a personal information survey instructed by the ICO in February 2008 revealed that around 40 per cent of UK users either were unaware of the DPA or had only recently learnt of its existence. See http://www.ico.gov.uk/upload/documents/library/data_protection/detailed_specialist_guides/icm_research_into_personal_information_feb08.pdf.

¹⁴⁰ Even in the US, where class actions by consumers are common, courts have on the whole failed to allow them in relation to data breaches, thus making effective claims by consumers for damages almost impossible—see A Matwyshwn ‘Behavioural Targeting of Online Advertisements and the Future of Data Protection’ [2009] *Journal of Computers and Law*, available at www.scl.org.

¹⁴¹ Scotland has its own legislation, the Freedom of Information (Sc) Act 2002.

mation held by public authorities. The Act provides that any person, legal or natural, has a right to know whether information, either about oneself or a third party, of a particular kind is held by a public authority, and to have that information communicated, and the public authority concerned has to reasonably accommodate the applicant. The request for information has to be in writing, and the applicant has to sufficiently identify himself and pay the fees prescribed. The FOI Act interacts with the DPA in that a FOI request can be refused if it relates to 'personal data or if disclosure of the information would contravene any of the data protection principles'.¹⁴² The reasoning behind this is that the data subject already has subject access rights to his own data, and access by others should depend on the data subject's consent. Thus personal data is exempted from FOI requests.¹⁴³ This interaction raises again the difficulty of exactly ring-fencing what is 'personal data', as already seen in the case of *Common Services Agency v Scottish Information Commissioner*¹⁴⁴ where the issue was whether health data anonymised by an algorithm that could easily be broken might not yet in some circumstances be 'personal data'.¹⁴⁵ The definition of personal data looks set to be driven by courts in the FOI field just as much as DP in future.¹⁴⁶

VI. DOES DATA PROTECTION LAW WORK IN CYBERSPACE?

The scheme described above is generally regarded as a careful and comprehensive approach to the protection of personal data and online privacy, applying internationally recognised fair information principles. The practice has, however, been less satisfactory, and the rise of the Internet as a marketing medium has in particular revealed dismayingly gaps in the tapestry of DP law. The EU has tried to patch over the difficulties with the PECD,

¹⁴² FOI Act 2002 s 40.

¹⁴³ On the general policy issues involved in the clash between FOI and data protection rights, see a European perspective from P Kleve and RV De Mulder, 'Privacy Protection and the Right to Information: In Search of a New Symbiosis in the Information Age', in S Kierkegaard (ed), *Cyberlaw, Security & Privacy* (International Association of IT Lawyers, 2007) 201–12, available at <http://ssrn.com/abstract=1138287>.

¹⁴⁴ Above n 75.

¹⁴⁵ See also *Mr C P England and London Borough of Bexley v Information Commissioner*, 10 May 2007; *Lancashire County Council v Information Commissioner*, 27 March 2007; , The Corporate Officer of the House of Commons v Information Commissioner, and Norman Baker MP (as an additional party), 16 January 2007; *A v The Information Commissioner*, EA/2006/0012, 11 July 2006.

¹⁴⁶ See also the EC law case of *Bavarian Lager*, above n 100 , which, while not directly about FOI legislation in the UK sense, deals with the same clash between principles of open access to public bodies and their documents, and the protection of personal privacy. In that case, the Court of First Instance held that public disclosure of the personal names of representatives at a public-sector body meeting making a certain critical decision *should* be allowed, since although the names were technically 'personal data', disclosure was not capable of actually and specifically affecting protection of the privacy and integrity of the persons concerned.

both before and during its current reform process, but as we shall see in the next two chapters, that Directive is still being outstripped by new technologies. What are the challenges that have arisen to make DP so problematic when applied to the new digitised and networked world? And does the DPD still operate to protect personal data in this new world in a more than formal manner or do we need a new Directive?

A. History and Focus of Data Protection Legislation: From Mainframes to Client–Server

As discussed above, historically, the European DP regime derived from the fear of a Stalinist-type ‘Big Brother’ state and was thus tailored mainly to restrict the surveillance activities of the state. Where control of private data gathering was envisaged, the model was that prominent in the 1970s and 1980s, ie mainframe technology. The cost and size of such machines was such that in the main only large and law-compliant organisations had the ability to collect, hold and process huge amounts of data about consumers. Such prominent commercial actors—helpfully described by Swire as ‘elephants’¹⁴⁷—were easy targets for the law and law enforcement agencies and privacy officials. Not only were they visible with established headquarters and attachable assets, but they also had a brand to consider and customer perceptions to worry about, and thus were likely to comply on notice or warning rather than require aggressive legal action. As a result, DP laws in the UK at least were generally designed to encourage negotiation-based settlement rather than actual prosecutions, and sanctions were set laughably low.¹⁴⁸ If ‘elephants’ are the main target of the legislation, DP is a practical privacy protection regime: bureaucratic, but enforceable.

The situation now is, however, very different. The trend since the dawn of the personal computer has been away from the mainframe model and towards a much larger number of smaller, more decentralised computers processing and collecting personal data. Computing power is ever cheaper, and chips have become small enough to fit intelligent processing of data into smartphones, digital televisions, etc. The client–server model has to a great extent displaced the mainframe/dumb terminal model: the Web, of course, is predicated on this paradigm. Servers, unlike mainframes, are easily moveable to wherever the legal, social and financial climate is most amenable.

The Internet, meanwhile, has opened up transnational selling and buying to a world that would never have had the resources in the pre-Internet world to transact across national borders. Data about European citizens, as

¹⁴⁷ See P Swire, ‘Of Elephants, Mice and Privacy: International Choice of Law and the Internet’ (1998) 32 *International Lawyer* 991.

¹⁴⁸ See discussion at p 467 above.

noted above, is now just as likely to be processed in India or the US as in the EU. Web publishing, blogging and related data-processing activities have become available to almost everyone, especially in the 'Web 2.0' world of user-generated content (UGC). Thus the number of potential 'data controllers' is suddenly in the millions, rather than thousands, and most are not subject to EU law enforcement. 'Data controllers' of this new kind—who fit the category Swire terms 'mice', since they are numerous, fast moving, fast increasing in numbers, easily able to run away and hide, and generally likely to be lacking in resources—will tend to be entirely untutored in DP, may not even know they have obligations under it, and usually lack legal expertise or advice. They will be less inclined towards legal compliance as they will in all likelihood lack a long-standing public profile and customer base, or internal bureaucracies to deal with the 'paperwork' of DP. They may even disappear, possibly to 'data havens', if realistic sanctions (or the threat thereof) are imposed on them.

The effect of all this was accurately predicted in 1998 by Peter Swire, the father of safe harbour:

Even within Europe, it is far from clear that a DP regime conceived for a limited number of mainframes can assure compliance in a world of pervasive personal computers. Outside of Europe, US and other website operators are even less likely to comply with the Directive, and many of these operators may remain beyond the jurisdiction of European law. Web sites will also likely be established outside of Europe to process data in ways that are forbidden by the Directive.¹⁴⁹

B. The Sheer Size and Scope of Cyberspace: Compliance, Oversight, Awareness and Resources

The trends that have been outlined so far—decentralised data control, trans-national data flows, and millions of data controllers—have clearly created problems for DP laws. These are further aggravated by the sheer size of the World Wide Web, the enormous volume of personal data it contains, and the huge number of people involved in donating and collecting personal data. Awareness of DP is low: as noted above, it is dull, fiddly and bureaucratic. Both data controllers and data subjects tend to report near ignorance of DP law and duties. In the February 2008 Eurobarometer survey, only 56 per cent of data controllers polled (selected from a sample which spanned from companies of over 20 employees to giant corporations, and did not include one-man businesses) said they were familiar with DP, and only 13 per cent were very familiar. Only 4 out of 10 respondents said their company had a privacy policy. Almost none reported familiarity with privacy enhancing technologies (PETs). Of data subjects, only a quarter

¹⁴⁹ P Swire and R Litan, *None of Your Business: World Data Flows, E-Commerce and the European Privacy Directive* (New York, Brookings Institution Press, 1998) 69–70.

reported knowing all their rights under DP law, and only 28 per cent knew of the existence of their state data protection commissioner. Pressure to implement and comply with DP law comes thus largely not from the public, nor from shareholders who see DP purely as an overhead. Knowledge is sparse and most DP implementation is by internal human resources staff rather than lawyers. European consumer organisations concerned with online privacy, such as the Online Rights Group (ORG) and the Foundation for Internet Privacy Research (FIPR), have also yet to acquire the same high profile that organisations such as the Electronic Freedom Foundation (EFF) and the American Civil Liberties Union (ACLU) arguably have in the US.

Privacy commissioners, who cannot be funded by commerce and remain independent, and are the poor man of state support, also have few resources with which to fight the giant battle of DP compliance. In the UK, the HMRC scandal of October 2007 may have, if temporarily, changed the playing field (see above) and awoken the public to the risks and harms associated with negligent data security—but in general, there are few votes to be got from putting money into privacy, and much backing to be gained from liberalisation of the market from ‘red tape’. This takes us to consideration of why DP is not only out of touch with the reality of the modern data-saturated world, but also unpopular with the commercial world.

C. The Globalised Nature of the Internet and Modern Corporate Business Models

One of the key problems with meaningfully enforcing EU DP law, as noted already above, is the problem of applying EU rules to a distributed globalised virtual world of data exchange. The US is still the driving force of the Internet and e-commerce world, and most personal information about UK consumers will probably still be collected by US-based businesses, websites or servers, or their subsidiaries in Europe.¹⁵⁰ But the US protects data exported from the EU, if at all, by means only of the much-criticised ‘safe harbour’ compromise,¹⁵¹ and has shown little or no interest in moving further towards a European-style omnibus legal data privacy regime. (Indeed such tentative moves as there were in that direction after the 1998 negotiations seem to have retreated in the wake of the obsession with national security at the expense of privacy since 9/11.) Meanwhile small US web-based businesses, and especially the ‘mice’ who operate on the grey legal fringes, such as pornography sites, gambling sites and spammers, will probably continue simply to ignore EU DP law even where they interact

¹⁵⁰ It might be argued that the US might be displaced in time by Japan, Korea, China and other Asian-Pacific countries as IT and e-commerce leader. Since most of these still have no equivalent to EU-style data protection regimes, however, the problem persists.

¹⁵¹ See n 57 above.

with European consumers. And even compliant US businesses, as we have already seen, are increasingly abandoning what safeguards safe harbour offers in favour of the private standard terms legitimised by Article 26.

Jurisdictional rules do of course theoretically exist to try to deal with the problem of transglobal corporate data flows,¹⁵² but arguably the resources and the political will to enforce European rules effectively outside Europe simply do not. US industry has shown little desire to take on the financial burden of full DP compliance, nor does DP fit with the model of national and international data sharing between affiliate and subsidiary companies which has evolved in a competitive and increasingly merger-and-acquisition fixated market.¹⁵³ Tellingly, the same points have been echoed in European industry itself,¹⁵⁴ which has always struggled to catch up with the natural advantage the US has had as the first nation into the e-commerce market. Kuner, writing in a text oriented towards European business practice, notes: 'There have been increasing complaints by companies that European DP law is based on outmoded regulatory models and does not sufficiently take the requirements of electronic commerce into account', and then goes on to list seven factors underlying this statement.¹⁵⁵

D. Conceptual and Harmonisation Problems

Finally a problem unconnected directly to the rise of the Internet, but again, probably aggravated by it, has been a growing dissatisfaction at the degree of vagueness in the DP Directive and the consequent diversity of interpretation of key words and phrases throughout the EU Member States. One of the strengths of the DP regime, given that it deals with transnational data flows, should be that at least it harmonises the law in Europe;

¹⁵² See Art 4 of the DP Directive 1995, para 4(1)(c) of which states that a Member State may apply its national laws to a data controller if 'the controller is not established on Community territory, and for the purposes of processing personal data makes use of equipment, automated or otherwise, situated on the territory of the said member state, unless such equipment is used only for the purposes of transit through the territory of the Community'. Such a definition appears to catch the typical US based e-commerce website (eg Amazon.com) which sells goods or services to UK consumers and collects personal data about UK consumers using 'equipment' here. 'Equipment' is not defined, but is usually deemed to include conduits necessary for the 'processing' such as UK ISP wires, cables, routers, etc. See also discussion of Google cookies in Art 29 WP 148 (see n 79 above) which makes it clear EU jurisdiction applies even where 'equipment' consists only of software such as cookies.

¹⁵³ See P Drahos and J Braithwaite, *Information Feudalism: Who Owns the Knowledge Economy?* (London, Earthscan Publications, 2002); M Castells, *The Rise of the Network Society*, 2nd edn (Oxford, Blackwells, 2000).

¹⁵⁴ Regan notes that in the negotiations surrounding the 1995 DP Directive, many EU-based companies lobbied alongside US business for laxer laws: P Regan, 'American Business and the European Data Protection Directive: Lobbying Strategies and Tactics', in C Bennett and R Grant (eds), *Visions of Privacy: Policy Choices for the Digital Age* (Toronto, University of Toronto Press, 1999).

¹⁵⁵ Kuner, above n 18, 45–48.

but even this claim, it seems, is no longer really true. Debates have broken out about basic notions in the Directive such as ‘personal data’,¹⁵⁶ ‘equipment’ and ‘domestic purposes’;¹⁵⁷ some rules are so broad that their interpretation is wholly unpredictable; enforcement policies vary hugely from Member State to Member State, to the extent that multinational companies operate in a sort of ‘regulatory limbo’;¹⁵⁸ and in particular, the lynchpin of the Directive, the notion of ‘consent’, is increasingly deconstructed by the realities of commercial standard-form contracts, web click-through forms and browse-wrap contracts,¹⁵⁹ and consumer ignorance and lack of time.

VII. FROM PRIVACY TO DISCLOSURE: THE NORMS DON’T WORK?

We have tried to demonstrate above that the DP laws devised in the 1970s and 1980s are failing to protect personal data in a world of digitised data and global networks. Another issue, though, is whether a societal will still exists to protect privacy as a fundamental value, in the way that came naturally to the survivors of World War II and the next generation. An important cultural shift is happening; a ‘value gap’ seems to be opening up at the time of writing between those aged under 30 or so, who have grown up familiar with an Internet world, and the rest of the populace. We live now in a world where conversations that would once have been private are habitually conducted in public on mobile phones; where young (and even sometimes older) people are willing to display their worst character traits, their poor business sense and their sex lives on live public television if it brings them a brief dose of D-list celebrity stardom; and where, arguably, openness rather than seclusion has become the more admirable character trait among the young(er). It is amusing that *Big Brother*, used at the beginning of the chapter in the Orwellian sense of a society where total surveillance is used to maintain tyranny and terror, has become to a younger generation associated with the idea that public visibility is desirable and a chance to show off and grab the limelight. Britain was traditionally a rather discrete and private society; it now seems to be following the US towards more of a culture of openness.

What effect might this perceived shift of values, or norms, have on the regulation of privacy and its enforcement? And if members of society, perhaps the younger and less experienced members, are willing to give up their own privacy (or trade it for perceived advantages), then what will the consequences be, both for each individually and for society as a whole?

¹⁵⁶ See discussion earlier at n 73 and surrounding text.

¹⁵⁷ See discussion earlier at n 152, and of *Lindqvist*, above n 87.

¹⁵⁸ Kuner, above n 18, 37ff.

¹⁵⁹ See further Riefa and Hornle, ch 2.

An important case study here can be drawn from the world of social networking sites (SNSs). Sites such as MySpace, Facebook, Orkut, Linked-In, Bebo and Flickr have attracted students and seniors, business users and entertainment seekers, Americans and Europeans in ever-increasing numbers. SNSs¹⁶⁰ can be characterised as 'online social networks for communities of people who share interests and activities, or who are interested in exploring the interests and activities of others, and which necessitates the use of software'.

A. The Case of the Oxford Proctors and the Philosophy Student

In July 2007, Oxford proctors in charge of university discipline used Facebook to find evidence of students breaking university rules. Students, who, in post-exam hilarity, had held wild parties, sprayed each other with champagne or shaving foam, or thrown flour bombs at each other, often posted photos of these incidents on Facebook. Proctors combed Facebook for evidence of such incidents and caught a number of students *in flagrante*. As a result, some of these students received disciplinary e-mails or more vigorous sanctions. The response from students was dismay and shock. The student union claimed that the incident was a 'disgraceful' intrusion into the privacy of the students concerned. One caught perpetrator complained that she was 'outraged':

Alex Hill, 21, a maths and philosophy student, received an e-mail stating that three of her photos provided evidence that she had engaged in 'disorderly' conduct. 'I don't know how the proctors got access to it,' the St Hugh's College student said. 'I thought my privacy settings were such that only students could see my pictures . . . I'm outraged.'¹⁶¹

A key point raised by the Oxford case is whether Facebook and similar SNSs are indeed a 'private' space where the user has reasonable expectations of privacy, or a 'public' space where such expectations do not or should not exist.¹⁶² Ms Hill's 'outrage' at being stalked in an 'underhand' fashion by Oxford proctors seems to show an honest (if unreasonable?) belief that she was operating in a friendly private space. Should such attitudes be taken into account and reified by the law? Livingstone, researching attitudes of young persons in the UK to privacy on Facebook in 2006, found that young people had both a conflicted attitude to privacy and often were either ignorant or confused as to how far they could protect

¹⁶⁰ http://en.wikipedia.org/wiki/Social_network_service.

¹⁶¹ See 'Caught on Camera—and Found on Facebook', *The Times* 17 July 2007, at http://technology.timesonline.co.uk/tol/news/tech_and_web/the_web/article2087306.ece.

¹⁶² Interestingly, a recent UK Internet libel case asserts that blog sites are a public space and thus there is no reasonable expectation of privacy or anonymity there: see *The Author of a Blog v Times Newspapers Ltd* [2009] EWHC 1358 (QB).

themselves by altering privacy settings.¹⁶³ Barnes, working in the US, noted that there was also an apparent disconnect—which she named the ‘privacy paradox’—between ‘the way users say they feel about the privacy settings of their blogs and how they react once they experience unanticipated consequences from a breach of privacy’.¹⁶⁴ Put simply this means that users usually say they wish to protect their personal data but rarely do anything about it—at least until after harmful consequences have transpired. Students and young persons also clearly want to keep information private from *some* if not all persons, eg parents and teachers, but do not seem to realise Facebook is a public space. Such pervasive assumptions seem to go beyond mere ignorance to actually perverse perceptions of social network and virtual community spaces, especially odd given so many students of today are tech-savvy and (by definition?) well educated and familiar with information technology.

Privacy jurisprudence itself is conflicted about whether ‘privacy in public’ exists and should be protected. The ECtHR has been in the process for some years of recognising that privacy rights do exist even in public spaces, even where celebrities, the archetypal ‘public property’, make themselves accessible to press attention in public—most noticeably in the celebrated recent ECtHR case of *von Hannover*.¹⁶⁵ In the UK, the courts and the Press Complaints Commission have given spectacularly contradictory decisions concerning celebrity privacy in quasi-public spaces such as beaches.¹⁶⁶ On SNSs, where the whole purpose for users is to network and to expose parts of themselves so as to engender trust and communication, the discourse is hopelessly confused.

¹⁶³ See S Livingstone, ‘Taking Risky Opportunities in Youthful Content Creation’, *Poke 1.0*, London, November 2007, abstract accessible at <http://nms.sagepub.com/cgi/content/abstract/10/3/393>.

¹⁶⁴ S Barnes, ‘A Privacy Paradox: Social Networking in the US’ [2006] *First Monday* issue 11/9, September, available at http://www.firstmonday.org/ISSUES/issue11_9/barnes/, citing FB Viegas, ‘Blogger’s Expectations of Privacy and Accountability; An Initial Survey’ (2005) 10(3) *Journal of Computer-Mediated Communications* at <http://jcmc.indiana.edu/vol10/issue3/viegas.html>.

¹⁶⁵ Above n 13.

¹⁶⁶ See Anna Ford’s complaint about paparazzi taking photos of family beach holiday, not upheld, at <http://www.pcc.org.uk/news/index.html?article=MjAyNA>, and Gail Sheridan, complaint over use of long lens to photograph her in her own back garden, at <http://www.pcc.org.uk/news/index.html?article=NDUzNW>—both privacy complaints not upheld; cf JK Rowling, complaining of press photos taken while on a Mauritius beach as family holiday, upheld, at <http://www.pcc.org.uk/news/index.html?article=MjA0NQ>, despite very similar circumstances to Ford. (See also Rowling’s sympathetic treatment in the courts in *Murray v Big Picture*, above n 8.) The PPC is not a court and asserted in the Rowling complaint that it did not have to follow its prior decisions, especially Ford, though it would have regard to them. See also apology to Sara Cox, equivalent of ‘settlement’, at <http://www.pcc.org.uk/news/index.html?article=Mjg2MQ> = . Interestingly, following a number of complaints, the PCC has recently commissioned a report into whether use by newspapers of information found on SNSs is abusive of privacy and should be a breach of the PCC Code: see http://blogs.guardian.co.uk/greenslade/2008/02/pcc_faces_up_to_facebook_intru.html. Complaints about media treatment of privacy can also be directed to Ofcom where broadcasters are involved: see eg complaint by Mr Gareth Nixon at http://www.ofcom.org.uk/tv/obb/prog_cb/obb112/issue112.pdf (unsuccessfully) complaining of being filmed binge-drinking in public.

B. Social Networking Sites and Data Protection Law

Social networking site operators are of course data controllers, and so under DP law they must, in pursuit of 'fair processing', gain the consent of their users to process their personal data—and indeed, 'explicit consent' in the case of sensitive personal data¹⁶⁷ (which abounds on SNS—in almost every Facebook profile a user reveals his or her race, politics, sexuality or religious beliefs, since these are predetermined fields in the user profile, which most users fill in without much thought). However, this consent is invariably obtained, since it is required as part of registration before 'admission' to the site is granted. In the SNS world, consent is usually obtained by displaying a privacy policy (or terms and conditions) on the site and asking the user to accede to them by ticking a box. As there is no chance to negotiate, and little or no evidence that users either read or understand these conditions, it is hard to see how this consent is 'free and informed' (see earlier discussion)—yet business practice for the entire sector seems to regard this consent as satisfactory. A further problem arises where SNS *users* display facts or images about other users—eg commonly, photographs featuring multiple persons. Such users rarely seek prior consent and such software tools as are made available usually only facilitate *post factum* removal, for example, of 'tags' on Facebook. As in the discussion of *Lindqvist* above, the question again arises as to whether ordinary users should be subject to the full panoply of DP obligations vis-à-vis their peers, and if they are not, how invasions of privacy by users rather than the site itself should be controlled. One suggestion has been that sites should be subject to liability for invasion of privacy if they do not take down expediently on complaint.

Many SNS users give away their personal data with alacrity because they feel they have nothing to hide, and many more make the same choice (if it is to be called a 'choice') simply because social networking is fun and trendy. Personal choices deserve respect, but inertia is something different; and the autonomy to make choices should also be balanced against the risks users are not fully equipped or informed to consider, especially the young and vulnerable. SNSs can aptly be described as a stalker's¹⁶⁸—and a voyeur's—paradise. People and companies collect the apparently harmless data disclosed by SNS users—including birthdates, house addresses, e-mail addresses, telephone numbers, friends, relatives, and pet names or nicknames (often used as clues to passwords for the likes of online banking)—for a variety of dubious purposes. These range from legitimate

¹⁶⁷ Although note the earlier comment that processing of sensitive data may not require explicit consent where users have made it public themselves—see n 102.

¹⁶⁸ The first UK prosecution for harassment explicitly involving Facebook was initiated in March 2008. See <http://www.out-law.com/page-8913>.

law or norm enforcement purposes (as in the Oxford case itself¹⁶⁹), to stalking by friends, strangers or perhaps ex-partners, to surreptitious mining of data without consent for economic exploitation by inter alia spammers, fraudsters, direct marketers, data miners and identity thieves;¹⁷⁰ to government surveillance when looking for terrorists or threats to national security. There are also worries about the use of data disclosed on Facebook etc by the media and press.¹⁷¹

Data disclosed on SNSs may persist for unknown lengths of time and acquire significance later that it did not have at the time of disclosure. The harmless pranks of today's youth, rather than disappearing into obscurity, may instead remain enshrined on an SNS and become a reason to be labelled as delinquent, denied admission to university or even employment, promotion or insurance, at some indefinite future time. One of the most worrying aspects of the SNS phenomenon is the generally acknowledged surge in their use by employers and other institutions as a means to screen applicants.¹⁷² Social network profiles also have a bad habit of persisting, even when the site appears to offer means of deletion.¹⁷³ Even where the site does provide effective deletion mechanisms, disclosed data may still be available via Google cache¹⁷⁴ or archiving sites such as the Way Back Machine. Such concerns about persistence, yet again, do not seem to have communicated themselves to younger users. A study by the UK Information Commissioner's office (ICO) in 2007 found that almost 60 per cent of UK 14–21 year olds did not realise the data they were putting online could be

¹⁶⁹ See also the news that Scotland Yard specifically patrols Facebook for crooks, at http://www.theregister.co.uk/2008/04/25/met_police_social_networking/ and the use of sites like Bebo and Facebook to crack down on anti-social youths in central Scotland, reported at http://news.bbc.co.uk/1/hi/scotland/tayside_and_central/7430993.stm.

¹⁷⁰ See 'Cyber Thieves Target Social Sites', BBC News, 3 January 2008, suggesting that in 2008 SNSs would become 'an attack vector for the hi-tech gangs who are behind the vast majority of cybercrime', available at <http://news.bbc.co.uk/1/hi/technology/7156541.stm>.

¹⁷¹ See n 166 above and 'Facebook Profiles Need Shielding from Media Intrusion', *OUT-Law News*, 9 June 2008. In a survey commissioned by the Press Complaints Commission, 78 per cent of users said they would change what they post about themselves online if they thought the media might use it.

¹⁷² See eg 'Would Be Students Checked on Facebook', *Guardian* 11 January 2008 (Cambridge University tutor admits to screening students via Facebook), available at <http://education.guardian.co.uk/universityaccess/story/0,,2238962,00.html>; 'Caught on Camera', *The Times*, above n 150 (survey of 600 UK companies revealed that one in five employers had used Facebook and other SNSs to screen applicants).

¹⁷³ Facebook, for example, were warned by the ICO when deleted profiles were still found to be accessible. They bowed to ICO and other pressure and guaranteed that total deletion of profiles would in future be possible—see <http://www.out-law.com/default.aspx?page=8882>. Facebook's terms and conditions were also subsequently changed after public disquiet so that Facebook was not entitled to continue to use data on a deleted profile after deletion.

¹⁷⁴ Facebook profiles were originally not made available to Google spiders. However, Facebook took a decision to make profiles available to Google and other search engines in September 2007. Interestingly, users were given an opportunity to opt-out of (rather than the more privacy-protective option to opt *in* to) having their profiles indexed. See discussion in this writer's blog, 'Facebook and Privacy Returns', *Pangloss* 5 September 2007, available at <http://blogscript.blogspot.com/2007/09/facebook-and-privacy-returns.html>.

permanently linked to them, and were generally horrified when this was suggested.¹⁷⁵

Dissemination to hostile third parties and persistence of disclosed data are by no means the only threats. Social networking sites also often allow third-party software programmes (sometimes called 'apps') access to user data. Facebook, the leading UK SNS, has built much of its appeal on these services. Again, user consent is usually sought in the most formal sense (ie give consent or you cannot use the app), but typically the user must give away *all* their personal data on the SNS or not be able to access the software at all—even if all the app does is something as simple as send a friend a 'virtual' bunch of flowers, requiring almost no data. Once data has been divulged to third parties via an app, that data is effectively beyond the control of both user and the SNS site itself. It is possible that the SNS may contractually require the third-party app developer to take reasonable security precautions and accord with local privacy laws—but the user will not usually see that contract before agreeing to install the app, nor be party to it, nor have title to enforce it.

To make matters worse, many apps are 'viral', in the sense that a user cannot sign up to them, or get results out of them, unless they pass the app on to 10 or 15 other friends on the same SNS first. What this boils down to is that the price of entry is not only giving away your own details but also those of your friends. Being viral, such apps spread rapidly. And being, on the whole, trivial applications, users rarely stop to think whether sharing data with unknown third parties is wise or in their best interests. All in all, it might be suggested that the easiest way to become an identity thief in the SNS world is to simply write a popular app, sit back, and gather all the personal information you want. Interestingly, the June 2009 Article 29 Working Party Opinion on SNSs¹⁷⁶ takes especial note of the threat to privacy of third-party apps, and suggests, first, that the SNS operator should 'have means to ensure that third party applications comply with the DPD' and secondly, that the APIs which allow the app access to user data held by the SNS should be written in a way that provides for granularity—so that users need *not* be asked for all their data just to send a virtual bunch of flowers.

Are there ways in which the users can still have fun and interact on SNSs, while protecting the, shall we say, naïve user from the consequences of their actions? The conventional answer is consumer education:¹⁷⁷ persuade

¹⁷⁵ See full report at http://www.ico.gov.uk/upload/documents/library/data_protection/detailed_specialist_guides/research_results_topline_report.pdf. One respondent to the survey (female, age 14) replied 'Initial thoughts – who cares? Subsequent thoughts – omg!'

¹⁷⁶ Opinion WP 5/2009, above n 93.

¹⁷⁷ See *Home Office Good Practice Guidance for the Providers of Social Networks etc* (2008), available at <http://police.homeoffice.gov.uk/publications/operational-policing/social-networking-guidance?view=Binary>.

consumers to read privacy policies and think about the dangers, perhaps compare different sites on the market, teach them to use the privacy tools the sites make available, and everything will be alright. This author is, however, rather dubious of this solution.¹⁷⁸ Consumers, especially the young, the elderly, the less well educated and the technophobic are not good judges of the risks of disclosure of personal data on the Internet, especially when the advantages—popularity, networking—are so much more tangible and present. Nor are they likely to put effort into learning how to use often well-hidden privacy features or read legalistic privacy policies: these are not entertaining activities. Common sense as well as scientific evidence say that people prefer jam today and disregard risk tomorrow. SNS users are particularly unlikely to worry about the privacy of *other* users, and at present one common problem is how easy many SNS platforms make it to ‘tag’ photos of third parties (who may or may not be members of the SNS too) without their knowledge or prior consent.

SNS operators themselves, for all the prevalent rhetoric of being alert to the safety and needs of their users, have little economic reason to respond to fairly non-existent customer pressure to produce more privacy-protective terms and conditions or defaults—for the simple reason that their business model is usually entirely based on collecting data from users and selling it directly or indirectly to advertisers. Since the sites themselves do not generally charge an entry fee, what they are really selling to stay in business is, in the main, their user’s data—in other words, their privacy.

The law is, however, used to dealing with consent as a faulty risk management process in the context of consumer law. Many laws require provision of pre-contractual information to consumers, and prejudicial terms in standard term contracts, which indicate a significant imbalance in bargaining power, can be struck down as unfair terms under UK and EU law.¹⁷⁹ There are no cases in the UK as yet of such clauses in SNS privacy policies or terms and conditions being attacked, though in the US an arbitration clause that was part of the ‘rules’ of an online virtual world has been successfully struck down.¹⁸⁰ Such victories are rare, however, and in any case most users have neither the knowledge nor the desire to take court

¹⁷⁸ Fascinatingly, a recent Cambridge survey of 45 SNSs showed that sites rarely made efforts to promote privacy as a selling point, and in fact that the sites which made the biggest efforts to promote and implement privacy tools tended to do badly in terms of audience growth. This does not reassure that the market will respond positively to forefront privacy, and does explain why privacy settings are so often metaphorically printed in grey on grey. See J Bonneau and S Preibusch, ‘The Privacy Jungle: On the Market for Data Protection in Social Networks’, Workshop on the Economics of Information Security, 2009, UCL, London, at <http://weis09.infoseccon.net/files/156/index.html>.

¹⁷⁹ See further discussion in Riefa and Hornle, ch 2. See in the UK, the Unfair Contract Terms Act 1976 as amended, and the Unfair Terms in Consumer Contract Regulations 1999 SI No 2083, and at EU level, EC Unfair Terms Directive 1993 93/13/EEC: L 95/29.

¹⁸⁰ *Bragg v Linden Labs*, 30 May 2007, District Court for E, Pennsylvania, Civil Action No 06-4925.

action against their favourite social network (and run the risk of being thrown off it and losing contact with their friends).

A better and far more effective approach than private parties taking contractual challenges to SNSs might be for the *state* to regulate SNSs by legally requiring them to amend their software—their ‘code’—to protect the average user’s personal data from obvious threats. In SNSs, for example, it is very often possible to restrict sight of a user’s profile to the people who have been defined as that user’s ‘friends’ or ‘buddy list’, but in general profiles are public by default, and user have to take positive efforts to restrict their profile in this way. If the site itself made ‘friends-only’ the default—which the user could then choose to ‘opt-out’ of—then users would be far better protected against the likes of spammers and identity thieves, etc. Instead, however, privacy-enhancing tools of this kind are frequently unobvious or difficult to use. The cynical might imagine that this is because, as noted above, the revenue stream from the SNS *comes* from third parties—advertisers—having access to as much data, on as many profiles, as possible. The UK Home Office code of conduct for SNSs released in 2008 suggests that the profiles of minor users at least should by default be locked to friends-only¹⁸¹ while the Article 29 Working Party Opinion on SNSs recommends not only ‘privacy-friendly default settings’ for all users, but also that restricted access profiles should not be found using internal search engines. This seems the beginning of the right way forward.¹⁸²

A practical approach, might be for users, when they join an SNS or similar site, to be automatically taken through an ‘install routine’ as is the norm when installing a piece of software. This routine could ask the user in simple language what data they want to disclose, who they want to be able to see it, and perhaps how long they want it to exist for. This would be far more effective than expecting the user to learn proactively to use well-hidden privacy preferences. There is also no reason, for example, why users could not be prompted to decide if they want to keep their profile going, say every six months, which might at least partially overcome the problem of the ‘leftover’ persistence of the records of youthful folly. Third-party apps might be required to implement code (as the Article 29 Working Party suggested) so as to obtain only the data necessary to fulfil their function.

These are all ‘code’ solutions that could be implemented fairly easily if imposed by law or mandatory industry code of practice. Finally, SNS sites

¹⁸¹ Above n 177.

¹⁸² See also discussion of future regulation of SNSs in the UK in the Byron Report, ‘Safer Children in a Digital World’ (2008), at <http://www.dfes.gov.uk/byronreview/pdfs/Final%20Report%20Bookmarked.pdf>. In Europe, ENISA, the European security agency, has also called for regulation: see ENISA Position Paper No 1, ‘Security Issues and Regulation for Online Social Networks’ (October 2007), at http://www.enisa.europa.eu/doc/pdf/deliverables/enisa_pp_social_networks.pdf.

could be forced to allow interoperability between their sites and other proprietary venues. In simple terms, this would mean that if a user was unhappy with the protection they received on site A, they could pick up their profile along with their 'friends list' and move it to another site. Such data portability would engender real competition between sites to attract users, which might lead to more concern for user rights, and less for advertisers.

VIII. THE DEATH OF PRIVACY?

Does the social networking phenomenon described above really indicate a sea change in attitudes to privacy? And if so, is this yet another reason why DP law needs to be amended or wholly rejected? We have already shown that corporations view DP as a business impediment, that DP deals badly with global data flows, that oversight authorities are underfunded and underpowered, and that consumers either know little about DP or have little faith in it. If consumers are furthermore rejecting privacy as a fundamental value, then the future for DP is bleak.

But this is not the true, or at least the complete, story. Conceptions of privacy are certainly changing, but the need on the one hand for private space, where people can make choices and enjoy intimacy without intrusion, and on the other for protection from 'privacy harms'¹⁸³—fraud, spam, misuse of personal data, identity theft—has not disappeared. The SNS phenomenon shows that perceptions of 'private space', and of risk, are flawed—not necessarily that the young have no interest in privacy. It also shows that much of personal privacy is about granular control: I may want to share all my data with X, some with Y and absolutely none with Z. The HMRC scandal meanwhile shows viscerally that when the state loses our data, and the risks and consequences of that loss are obvious, the public is still visibly appalled. Furthermore, even after the blip that 9/11 has caused, the public is beginning to reassert in poll after poll that it is not keen on unrestricted public surveillance by both the state and commercial entities.¹⁸⁴

What happens next? The European Commission is due to review the DPD in the near future and has already nearly completed the process of amending the PECD (as discussed at points above). There will almost certainly be further changes of detail to come to deal with phenomena like radio frequency identification (RFID) (discussed in chapter 16), mobile

¹⁸³ The concept of 'privacy harms' is expanded on in L Edwards, 'Reconstructing Consumer Privacy', above n 1, 317–18.

¹⁸⁴ In the February 2008 Eurobarometer poll, only 16 per cent of the sample approved of unrestricted state monitoring of phone calls, and only 25 per cent were happy to have their Internet use monitored.

computing, distributed processing,¹⁸⁵ and perhaps social networking. But will there be serious changes of principle? As Hustinx, the European Data Protection Supervisor, said in November 2007:

The Internet . . . is the most fundamental revolution in data collection and data transfer since the printing press. If the most fundamental revolution in the last 500 years is not going to present some challenges to traditional notions of DP, then I do not think we are challenging ourselves to think things through.¹⁸⁶

At the international human rights level, change is clearly afoot, and the accumulation of threats to privacy in a digital world is being rebutted in a variety of interesting contexts. We have already noted the increasing presence of the ECtHR in what might generally be regarded as DP areas, from the perspective of Article 8 of the ECHR. In EU courts, the ECJ recently asserted in the *Promusicae* case that the rights of the entertainment industry to find out who is illegally downloading music and movies do not necessarily trump the privacy rights of Internet users. Instead they opined that Member States and their courts 'must take care to rely on an interpretation of [the DPD and the Copyright Directives] which allows a fair balance to be struck between the various fundamental rights protected by the Community legal order'.¹⁸⁷ In Germany, the Constitutional Court has radically declared a new fundamental right of privacy, confidentiality and integrity in computer systems.¹⁸⁸ The EU Charter of Rights, which may or may not become a mandatory part of EU law at the time of writing under the Lisbon Treaty, declares as well as the familiar right to a private life, the right to protection of personal data.¹⁸⁹ Even in the US, not historically a privacy-protective jurisdiction, the Supreme Court of New Jersey has recently declared for the first time that US citizens have a 'reasonable expectation of privacy' in personal data they supply to Internet service providers.¹⁹⁰

¹⁸⁵ On both of these, see A Charlesworth, 'The Future of UK Data Protection Regulation' (2006) 11 *Information Security Technical Report* 46—sadly, space precludes further discussion of these important topics here. See also on future reform of EC DP law, Y Pouillet and J-M Dinant, 'Towards New Data Protection Principles in a New ICT Environment' (IDP, 2007), available at http://www.uoc.edu/idp/5/dt/eng/pouillet_dinant.pdf.

¹⁸⁶ See report of Hustinx debate with Google Privacy head, Peter Fleischer, at *OUT-Law News* 9 November 2007 at http://www.theregister.co.uk/2007/11/12/privacy_law_debate/.

¹⁸⁷ *Promusicae v Telefonica*, European Court of Justice, 29 January 2008, Case C-275/06, para 68.

¹⁸⁸ 27 February 2008. Judgment available in German at http://www.bverfg.de/entscheidungen/rs20080227_1bvr037007.html. See discussion at <http://www.tjmcintyre.com/2008/02/german-constitutional-court-recognises.html>.

¹⁸⁹ Art 8; 2000/C 364/01.

¹⁹⁰ *New Jersey v Reid*, Supreme Court of New Jersey (A-105-06) 21 April 2008.

A. Code and Privacy

As indicated above, though, law is not the only solution, or at least traditional law of the current DP variety. Legislators must increasingly think about how ‘code’ can be manipulated to protect privacy, rather than legislating as is traditional at a principled level, to regulate *people* rather than technologies. The European Commission has repeatedly declared its support for privacy-enhancing technologies (PETs),¹⁹¹ though it does not yet seem to have found a way to convince the general public of their value, or indeed, existence.¹⁹² Above, we have given several examples of how regulated code might protect the users of SNSs rather better than mere abstract DP laws. The associated concept of ‘privacy by design’, as discussed further in subsequent chapters, is also receiving serious attention, in the UK¹⁹³ and globally.¹⁹⁴ This is, in essence, the idea that privacy should be ‘engineered in’ early in the process of designing systems, especially large multi-user databases, rather than strapped on after the main design is complete as a half-hearted add on. The emphasis here is on *data minimisation*—collecting less data ab initio, by code means and also by reliance on legal principles such as the Australian rule that systems must be designed to allow an anonymity option if practical. This idea of privacy built in *ex ante* rather than *post factum* may yet transform the field.¹⁹⁵

Turning back to law, it may be that we have to abandon the idea of DP law as a one-size-fits-all regime. Different legal and non-legal solutions may fit different sectors of activity. In the traditional heartland of DP, the protection of the citizen from state surveillance, DP clearly still has an outstandingly important role to play, simply because the state has such power to affect the everyday life and privacy of citizens, and so *must* be seen to be law compliant. The problems here seem in essence political and organisational rather than conceptual: political will for compliance, enforcement powers, training of public officials, resourcing issues, education of citizens, etc.

In the commercial world, however, there do seem to be real issues about whether the principles of a regime created for a world of relatively small numbers of non-networked mainframe computers still work in a world of

¹⁹¹ See most recently *Communication from the Commission to the European Parliament and Council, Promoting Data Protection by PETs*, Brussels, 2 May 2007 COM(2007) 228 final.

¹⁹² Eurobarometer reported that only 39 per cent of UK data subjects had ever even heard of let alone used PETs—the fourth lowest score in the EU.

¹⁹³ See eg the ICO report, ‘Privacy by Design’ (26 November 2008) available at http://www.ico.gov.uk/about_us/news_and_views/current_topics/privacy_by_design.aspx.

¹⁹⁴ See eg in Canada, A Cavoukian, *Privacy by Design.. Take the Challenge* (Information and Privacy Commissioner of Canada, 2009).

¹⁹⁵ Interestingly, the first British Standard (BS 10012:2009) on the management of personal data was published in June 2009 (*OUT-LAW News* 3 June 2009). This raises the interesting question of whether technical and organisational standards might be a better medium than law for setting standards in a field like DP.

multiple data controllers, distributed global data flows and mobile ubiquitous data usage. It is possible that regulators should be directed here to apply one set of rules and sanctions to large database operators, and another to small to medium-sized operators. One key problem, which will be discussed at length in the following two chapters, is whether consent has any meaningful role left to play as a safeguard for consumers giving away personal data online to information society service providers.

In the personal world of social networking and the like, the problem of meaningful consent recurs but other factors are different again. One key problem is that created by the *Lindqvist* case; the idea that every domestic Internet user who contributes content to Web 2.0 sites like Facebook or Twitter is a data controller with the same set of obligations in principle as Virgin or HSBC is clearly absurd. As noted earlier, this is an area ripe for reform.

One argument, in which this author has increasingly little faith, however, is that the problem of disclosure of personal data on SNSs may be a 'blip' problem. The youth of today may be currently enthusiastically giving away their personal data on the Internet, this argument goes, but the next generation will be very well versed in how to manipulate the Internet and have no problem locating and using privacy defaults and similar controls. This seems to ignore the point that consumers as a herd tend to be reactive and not take safeguards until the worst has already happened. An even more hopeful suggestion is that in time we will turn into a more forgiving, sympathetic society; if the eternal memory of Google remembers everyone's faults equally, we will perhaps have to, in turn, employers and lovers, colleagues and referees, forgive each other's sins for fear of being equally castigated. As the employment appeal tribunals fill with Internet-related cases, this also seems somewhat far off.

Finally some suggest simply that privacy is becoming an outmoded concept: disclosure is in, privacy is out. On this, only time will tell. What is certainly true is that as the next generation of 'digital natives'¹⁹⁶ grows up to become adult consumers of the information society, their privacy needs, in the public, private and cultural sectors, are going to be no less but very different than those of current users. Multiple online identities, distributed and federal identity management, aggregate or group profiled data, and users who ascribe their loyalty to no particular territorial jurisdiction as respects their online life, are all going to be challenges for the next iteration of DP.¹⁹⁷

¹⁹⁶ See J Palfrey and U Gasser, *Born Digital: Understanding the First Generation of Digital Natives* (New York, Basic Books, 2008).

¹⁹⁷ Note that as this book went to press, the European Commission finally formally launched a consultation towards reforming the DPD; see Consultation on the legal framework for the fundamental right to protection of personal data, 9 July 2009.

In the next four chapters we examine in detail emerging problems for DP and privacy in first, the commercial world, and secondly, the world of state surveillance.